IMS for Communications Data Acquisition

A Design and Technical Governance Course

Prepared for Michael Rossi

September 2026

Contents

How to Use This Course **4**
What this course is . . . 4
Who it is for . . . 4
Structure . . . 4
Conventions . . . 5
An honest caveat . . . 5

Part I — The Problem Domain **6**

Module 1 — What CDA Is, and Why It Is Hard [C] **7**
1.1 The one-sentence definition . . . 7
1.2 Where CDA sits among the powers . . . 7
1.3 The parties . . . 8
1.4 The shape of a request, end to end . . . 8
1.5 The five structural tensions . . . 9
1.6 Why IMS makes it harder than it used to be . . . 9
Key takeaways . . . 10

Module 2 — The UK Legal Framework [C/G] **11**
2.1 The structure . . . 11
2.2 The acquisition power: Part 3 . . . 11
2.3 The retention duty: Part 4 . . . 12
2.4 Notices to operators: Part 9 . . . 13
2.5 Oversight, and what it demands of the design . . . 13
2.6 Translating law into requirements . . . 14
Key takeaways . . . 14

Module 3 — The Data Taxonomy [C/D] **15**
3.1 The three categories . . . 15
3.2 Worked classification . . . 15
3.3 Where the content boundary actually bites . . . 16
3.4 Design controls the taxonomy demands . . . 17
3.5 Third-party data . . . 17
Key takeaways . . . 18

Part II — Where the Data Comes From **19**

Module 4 — IMS as a Data-Producing Machine [C/D] **20**
4.1 IMS in two minutes . . . 20
4.2 The nodes that generate data, and what each knows . . . 20
4.3 What one voice call actually produces . . . 21
4.4 What IMS does not tell you . . . 22
4.5 The charging-record temptation . . . 22
Key takeaways . . . 23

Module 5 — Identifiers and the Resolution Problem [D] **24**
5.1 The identifier zoo . . . 24
5.2 The three resolution problems . . . 25

5.3 Carrier-grade NAT, and why it breaks things . . . 25
5.4 Designing resolution defensibly . . . 25
5.5 Number portability and interconnect . . . 26
Key takeaways . . . 26

Module 6 — What the Data Can and Cannot Support [C/G] 27
6.1 The four honest limits . . . 27
6.2 The erosion problem . . . 27
6.3 What remains valuable, and is often under-exploited . . . 28
6.4 Setting expectations in practice . . . 28
Key takeaways . . . 29

Part III — Designing the Solution 30

Module 7 — Reference Architecture for a CSP Disclosure Capability [D] 31
7.1 The reference architecture . . . 31
7.2 Layer responsibilities in detail . . . 32
7.3 The three decisions that determine longevity . . . 32
Decision 1 — Where is content-bearing granularity removed? . . . 33
Decision 2 — Is retention a copy or the system of record? . . . 33
Decision 3 — How is scope enforced? . . . 33
7.4 A sequence through the architecture . . . 33
Key takeaways . . . 34

Module 8 — Designing the Retention Store [D] 35
8.1 Requirements the notice generates . . . 35
8.2 The correlation problem . . . 35
8.3 Data model shape . . . 36
8.4 Partitioning, expiry and deletion . . . 36
8.5 Capacity — and how to challenge a plan . . . 37
8.6 Quality controls at ingest . . . 37
Key takeaways . . . 38

Module 9 — Request Handling, Mediation and Handover [D/G] 39
9.1 What the interface has to carry . . . 39
9.2 The standards landscape . . . 39
9.3 The 3GPP architecture, at governance level . . . 40
9.4 Designing the interface: decisions . . . 41
Synchronous or asynchronous? . . . 41
How is the response delivered? . . . 41
Who resolves ambiguity? . . . 41
9.5 Securing the seam . . . 42
9.6 Urgent requests . . . 42
Key takeaways . . . 43

Module 10 — Security, Compartmentation and Insider Risk [D/G] 44
10.1 The threat model, stated honestly . . . 44
10.2 Compartmentation . . . 45
10.3 Access control that matches the law . . . 45
10.4 Encryption and key management . . . 45
10.5 Detecting misuse . . . 46
10.6 Vendor and supply chain . . . 46
Key takeaways . . . 47

Part IV — Assurance and Governance 48

Module 11 — Quality, Integrity and Evidential Weight [G] 49
11.1 Three different standards, often confused . . . 49
11.2 What evidential weight actually requires . . . 49
11.3 The quality framework . . . 50
11.4 Completeness statements . . . 50

11.5 Errors . . . 51
11.6 The assurance evidence pack . . . 51
Key takeaways . . . 52

Module 12 — Governing the Programme [G] 53
12.1 What is different about governing this . . . 53
12.2 The design authority . . . 53
12.3 Requirements that derive from law . . . 54
12.4 Vendors . . . 54
12.5 Change . . . 55
12.6 Failure patterns, and the early signal for each . . . 55
12.7 A first hundred days . . . 56
Key takeaways . . . 56

Appendix A — Design Review Question Bank 57
A.1 Scope and legal basis . . . 57
A.2 Data and sources . . . 57
A.3 Retention . . . 57
A.4 Query, scope and disclosure . . . 58
A.5 Interface . . . 58
A.6 Security and access . . . 58
A.7 Assurance . . . 58

Appendix B — Patterns and Anti-Patterns 59
B.1 Patterns worth adopting . . . 59
B.2 Anti-patterns, and what they cost . . . 59
B.3 Two worked design decisions . . . 60
Where to enforce scope . . . 60
Retention source for voice session records . . . 60

Appendix C — IMS Protocol Reference Annex 62
C.1 Nodes . . . 62
C.2 Identifiers . . . 62
C.3 Signalling elements that carry CD-relevant information . . . 63
C.4 Procedures that generate records . . . 63
C.5 Interfaces you may see named . . . 64
C.6 The 4G and 5G context in one table . . . 64

Appendix D — Legal and Standards Index 66
D.1 UK legislation and codes . . . 66
D.2 ETSI . . . 66
D.3 3GPP . . . 67
D.4 GSMA . . . 67

Appendix E — Glossary 68

How to Use This Course

What this course is

This is a course on **designing and governing Communications Data Acquisition (CDA) solutions**, written from the point of view of someone who has to make, challenge and assure design decisions rather than someone who has to configure a network element.

It is framed against the **UK Investigatory Powers Act 2016 as amended**, and it takes the **communications service provider (CSP) disclosure side** and **the interface and assurance between the CSP and the acquiring authority** as its subject. The acquiring authority's own internal tooling is referred to where it shapes the interface, but is not itself designed here.

It covers **communications data only** — the who, when, where and how of a communication. Content interception is a different power, a different legal test and a largely different design problem; the boundary between the two is drawn explicitly in Module 3 and then respected throughout, because in this domain a blurred boundary is a compliance failure, not a rounding error.

IMS appears because it is where a modern operator's voice, video and messaging records are made. But IMS is treated here as **a machine that produces data**, not as a call-control system to be operated. The protocol detail that a telco engineer needs is compressed into Appendix C, where you can check a fact without it interrupting the argument.

Who it is for

The material addresses three kinds of question, and every module is marked with the ones it serves:

Marker	Kind of question	Typical reader
[C]	*What is this and why does it work this way?*	Anyone new to the domain
[D]	*How should the solution be built?*	Solution architects, designers
[G]	*How do I know the design is right, and defend it?*	Design authority, assurance, governance

If you are coming to the domain new, read straight through. If you already know the law and need the architecture, start at Module 7. If you are reviewing someone else's design, Appendix A is a question bank built for exactly that and is the fastest route to a useful challenge.

Structure

Part I — The Problem Domain (Modules 1–3). What CDA is, the legal structure that determines every requirement in it, and the data taxonomy that determines what may lawfully be built.

Part II — Where the Data Comes From (Modules 4–6). IMS as a data-producing machine, the identifier and resolution problem that dominates real designs, and an honest account of what the data can and cannot support.

Part III — Designing the Solution (Modules 7–10). A reference architecture for a CSP disclosure capability, retention design, request handling and handover, and the security and compartmentation model.

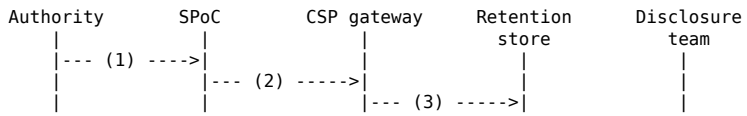
Part IV — Assurance and Governance (Modules 11–12). Data quality, integrity and evidential weight; and how to run the design authority for a programme of this kind.

Appendices. A design review question bank, architecture patterns and anti-patterns, the IMS protocol reference annex, the legal and standards index, and a glossary.

Conventions

Three devices recur.

Ladder diagrams show the sequence of a request or a data flow between parties. Unlike the protocol diagrams in a telecoms course, the parties here are usually organisations or systems, not network elements:



Design decision tables set out an option, what it buys, what it costs, and the condition under which each choice is right. They are written so they can be lifted into a design paper.

> **Governance note.** Boxes like this flag the point in a design where a governance decision is actually being taken, often without anyone noticing. They are the ones to put on a design authority agenda.

An honest caveat

Law in this area changes, and it changed recently: the **Investigatory Powers (Amendment) Act 2024** and the revised Codes of Practice brought into force during 2025 altered the notices regime, the internet connection record conditions, the bulk personal dataset regime and the section 11 offence. Every legal statement in this course is written as at September 2026 and is given so you know *what to look up*, not so you can rely on it. Before any statement here becomes a design constraint in a real programme, check it against the current Act, the current Code of Practice and your own legal advisers. This course is engineering guidance, not legal advice.

Part I — The Problem Domain

Module 1 — What CDA Is, and Why It Is Hard [C]

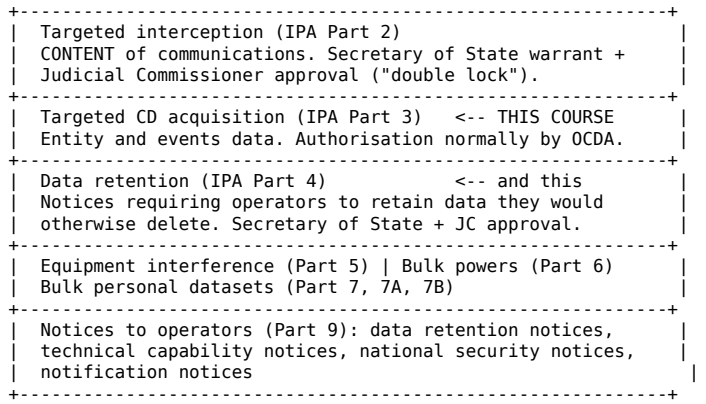
> **Objectives.** You can define communications data acquisition and place it against the adjacent powers; you can name the parties and what each owes the others; and you can state the five structural tensions that make every CDA design a compromise.

1.1 The one-sentence definition

Communications data acquisition is the lawful obtaining, by a public authority from a telecommunications or postal operator, of data about a communication — who, when, where, how and with whom — but not what was said.

Every word in that sentence carries design consequences. *Lawful* means an authorisation regime and an audit obligation. *From an operator* means an interface between organisations with different incentives. *About a communication* means a data taxonomy with a legally sharp boundary. *Not what was said* means a filter that must be demonstrably effective.

1.2 Where CDA sits among the powers



Two observations that matter more than they look.

Parts 3 and 4 are a pair. Part 4 makes the data exist; Part 3 obtains it. A CSP-side design that treats them as one system will over-retain; a design that treats them as unrelated will find that the retained schema cannot answer the questions Part 3 asks. Most of the interesting design work is in the seam.

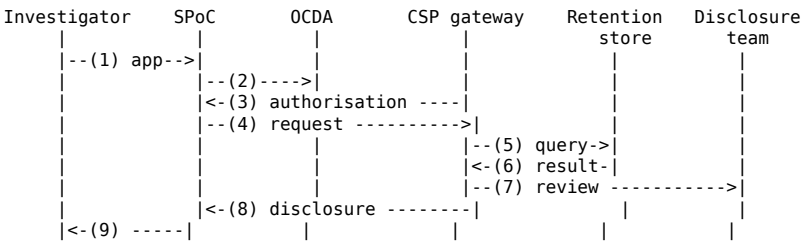
Part 9 is the design-forcing part. A data retention notice or a technical capability notice is where an operator's abstract duty becomes a concrete engineering requirement with a delivery date. If you are governing a CDA programme inside a CSP, the notice is your requirements baseline, and the fact that it is a legal instrument rather than a requirements document is a permanent source of friction.

1.3 The parties

Party	What they are	What they want
Acquiring authority	Police force, NCA, intelligence agency, or one of the other listed public authorities	Fast, complete, intelligible answers; ability to use the result evidentially
SPoC	Single Point of Contact — accredited staff within the authority who quality-assure and submit requests	Requests that will be authorised and will not be returned; a predictable interface
OCDA	Office for Communications Data Authorisations — independent authorisation on behalf of most authorities	Applications that demonstrate necessity and proportionality on their face
IPCO / IPC	Investigatory Powers Commissioner's Office — oversight and inspection	Auditable evidence that the regime was followed, at both ends
CSP / TO	The telecommunications operator holding the data	Minimum cost, minimum risk, clear scope, cost recovery, no surprises
CSP disclosure team	The accredited staff inside the operator who receive and answer requests	Unambiguous requests, tooling that does not require them to be engineers
Vendor	Supplier of retention, mediation and disclosure products	A scope that does not move; a reference architecture they recognise
Investigatory Powers Tribunal	Redress for individuals	—

> **Governance note.** The commonest structural failure in these programmes is designing for the acquiring authority's workflow when you are building the CSP's system, or vice versa. They have genuinely different obligations. The CSP's duty is to disclose what it holds, accurately, when lawfully required; it is not to investigate, to interpret, or to help build a case. Designs that quietly cross that line create both legal and commercial exposure.

1.4 The shape of a request, end to end



1. An investigator applies, stating the purpose, the necessity, the proportionality case, the data sought and the period.
2. The SPoC quality-assures and submits to the authorising body.
3. Authorisation is granted, refused, or granted in part. **This is a legal act, and everything downstream inherits its scope.**
4. The authorised request reaches the CSP — increasingly over a structured, machine-readable interface rather than by email or portal. 5.–6. The CSP resolves the request against what it holds.
5. Where required, a human in the disclosure team reviews the result before it leaves — for scope, for content leakage, and for third-party data. 8.–9. The disclosure returns, with provenance, to the SPoC and the investigator.

Nine steps, two organisations, at least four systems, one legal instrument and one audit trail that has to survive inspection years later. That is the design problem.

1.5 The five structural tensions

Every CDA design is a negotiated position between these. Naming them makes design reviews far more productive, because most disagreements turn out to be about which tension is being prioritised rather than about the technology.

1. Completeness versus minimisation. The authority wants everything relevant; the law requires no more than is necessary and proportionate; the operator wants to hold as little as possible. The design decides this in concrete ways: what is retained, at what granularity, for how long, and what a query is permitted to return.

2. Latency versus deliberation. A threat-to-life request needs an answer in minutes. The same pipeline must also support a request that will be scrutinised in court in three years. Optimising for one degrades the other, and pretending one pipeline serves both is a common and expensive mistake.

3. Automation versus human judgement. Machine-to-machine interfaces are faster, more consistent and more auditable. But some decisions — is this within scope, is this content, is this third-party data — are judgement calls that regulators expect a person to have made. The design decides where the human sits, and that placement is a governance decision disguised as a workflow decision.

4. Evidential weight versus operational speed. Data that will be used as evidence needs provenance, integrity and a chain of custody that can be explained to a court. Data used only to direct an investigation needs none of that. Building everything to evidential standard is unaffordable; building nothing to it is negligent.

5. Capability versus exposure. Every capability built — every retained field, every query type, every interface — is also an attack surface, an insider risk and a political liability. The most secure CDA system is the one that cannot answer the question; the least useful one is the same system.

1.6 Why IMS makes it harder than it used to be

In a circuit-switched network, a call produced one record, in one place, with one identifier for each party, at the moment the call ended. That world is gone.

Then	Now
One CDR per call, from the switch	Records from several IMS nodes, at several stages, for one call
One identity: the phone number	IMPI, several IMPUs, SIP and TEL URIs, GRUUs, IMSI, IMEI, IP address and port
The network carried the service	The network may carry someone else's service
A fixed location: the line, or the cell	An IP address that may be shared, carrier-graded, or a VPN exit
One operator end to end	Access operator, service operator, interconnect, and an OTT provider
Records existed for billing	Flat-rate bundles mean the commercial reason to generate records has gone

That last row is the one most often missed in governance. Historically, communications data existed because operators needed it to bill. Modern tariffs do not require per-event records, so increasingly the *only* reason a record exists is that the law requires it. That changes the engineering: retention becomes a purpose-built system rather than a by-product, and its cost

is a compliance cost with no commercial offset. Expect that argument in every business case you review.

Key takeaways

- CDA is the lawful obtaining of data *about* communications; content is a different power with a different test, and the boundary is load-bearing.
- Parts 3 and 4 of the IPA are a pair: one creates the data, the other obtains it. The design problem lives in the seam.
- A notice under Part 9 is where legal duty becomes an engineering requirement — and it is your requirements baseline whether or not it reads like one.
- Five tensions — completeness/minimisation, latency/deliberation, automation/judgement, evidence/speed, capability/exposure — explain most design disagreements.
- Modern networks have broken the assumptions the old model relied on: one record, one identity, one operator, and a commercial reason to keep it.

Module 2 — The UK Legal Framework [C/G]

> **Objectives.** You can describe the structure of the IPA 2016 as it bears on CDA, name the authorisation routes and who uses them, explain the four kinds of notice an operator may receive, and translate each legal concept into the design requirement it generates.

This module is a map, not a legal text. Its purpose is to let you recognise which legal instrument is generating a requirement, so that you can ask whether the design actually satisfies it.

2.1 The structure

The **Investigatory Powers Act 2016** consolidated powers previously spread across RIPA 2000, the Telecommunications Act 1984 and elsewhere. It has been amended, materially, by the **Investigatory Powers (Amendment) Act 2024**, with revised Codes of Practice brought into force during 2025.

Part	Subject	Relevance here
Part 1	General protections, offences	**s.11** offence of obtaining CD without lawful authority
Part 2	Targeted interception	Out of scope — content
Part 3	**Acquisition of communications data**	**The acquisition power**
Part 4	**Retention of communications data**	**The duty to hold it**
Part 5	Equipment interference	Out of scope
Part 6	Bulk powers, incl. bulk acquisition of CD	Adjacent; different regime
Part 7 / 7A / 7B	Bulk personal datasets	Adjacent; 7A and 7B added in 2024
Part 8	**Oversight**	IPC, IPCO, Technical Advisory Board, IPT
Part 9	**Miscellaneous — notices**	**Where duties become engineering**

2.2 The acquisition power: Part 3

An authorisation permits a *relevant public authority* to obtain communications data where doing so is **necessary** for one of the statutory purposes and **proportionate** to what is sought to be achieved.

The statutory purposes include national security; preventing or detecting crime or preventing disorder; the economic well-being of the UK so far as relevant to national security; public safety; preventing death, injury or damage to health; and a small number of others

including certain regulatory functions. Not every purpose is available to every authority, and not every purpose supports every data type.

Authorisation routes. Following the Data Retention and Acquisition Regulations 2018 — themselves a response to litigation about independence — the default is external authorisation:

Route	Who decides	Typical use
OCDA	Independent authorising officers acting for the IPC	The normal route for most authorities and most requests
Designated senior officer	A senior officer within the authority	Urgent cases, threat to life, and certain limited categories
Judicial Commissioner	JC approval	Where the statute requires it, e.g. certain sensitive professions
Internal, intelligence agencies	Agency internal authorisation with IPC oversight	National security work by the agencies

The serious crime threshold. For *events* data acquired for the crime purpose, the crime must meet the serious-crime threshold. *Entity* data may be acquired for the broader crime purpose. This asymmetry is one of the most important facts in the whole course, because it means **the entity/events distinction is not academic: it changes who may obtain what, on what grounds.** Any design that cannot reliably classify a field as entity or events data has a legal problem, not a data-modelling problem.

Internet connection records. ICRs are a defined subset of events data — broadly, the record of which internet service a device connected to, and when, generated by the operator in the course of providing the service. They are subject to their own restrictions in section 62, including which authorities may obtain them and on what conditions. The 2024 Act relaxed one of those conditions to support "target discovery" — identifying an unknown person from a pattern of service usage — for the intelligence services and the NCA, with continued IPC oversight.

> **Governance note.** ICR capability is the single most contested design area in CDA. If a programme you are governing is building it, expect the requirements to be ambiguous, the volumes to be badly estimated, and the political sensitivity to be high. Ask early and repeatedly: exactly which events constitute an ICR in our network, and who has signed that definition off?

2.3 The retention duty: Part 4

A **data retention notice** (DRN) may require an operator to retain specified communications data for up to twelve months. The notice is given by the Secretary of State and approved by a Judicial Commissioner, and it may specify the data, the period, the operator's obligations as to integrity and security, and the arrangements for disclosure.

Key features that shape the design:

- **Retention is compelled, not permitted.** The operator must retain what the notice specifies. It must *not* retain more than its other legal bases allow — data protection law still applies to everything else.
- **Retained data must be kept secure and to the same standard as the operator's own business data**, and must be destroyed at the end of the period unless another basis applies.
- **Retained data must be capable of disclosure without undue delay.** That is a performance requirement, expressed legally, and it is the origin of most of the latency requirements in a retention design.

- **Notices are now subject to statutory review timelines** following the 2024 Act and the 2025 notices regulations, where previously review could be open-ended.

2.4 Notices to operators: Part 9

Four instruments, and it is worth being able to tell them apart at a glance, because they generate very different work.

Notice	Power	What it does	Design consequence
Data retention notice	Part 4	Requires specified CD to be retained, up to 12 months	Build and operate a retention store
Technical capability notice	s.253	Requires the operator to maintain a capability to give effect to warrants and authorisations	Build and maintain interfaces and systems, in advance of any specific request
National security notice	s.252	Requires steps in the interests of national security	Varies; often infrastructure or access arrangements
Notification notice	s.258A (added 2024)	Requires the operator to notify the Secretary of State of relevant changes that would negatively affect capability, before making them	A **change-control obligation**: your release process becomes a regulated process

Three points about notification notices, since they are new and least understood:

- They apply to operators above a customer threshold — set at more than 10,000 customers in the implementing regulations.
- They require *notification*, not permission. The Secretary of State has no power under s.258A to approve or veto the change.
- Routine security patching is excluded.

  Governance note. A notification notice changes the *governance of your own delivery lifecycle*. Somebody must be able to tell, for every change going through your release process, whether it is notifiable. That is an architecture and impact-assessment capability, not a legal one, and if it is not designed deliberately it will be done by an overloaded human reading release notes. Put it on the design authority agenda before the first release, not after the first miss.

2.5 Oversight, and what it demands of the design

The Investigatory Powers Commissioner and **IPCO** inspect both authorities and, in respect of their obligations, operators. Inspection is evidence-based: inspectors look at records of what was requested, what was authorised, what was disclosed, and whether those three agree.

That produces a hard design requirement that is easy to underrate:

Every disclosure must be reconstructable. Years later, you must be able to show: the request as received, the authorisation it cited, the query actually executed, the data actually returned, who saw it, and when everything was destroyed. If your architecture cannot produce that narrative from its own records, it is not compliant regardless of how correctly it behaved at the time.

The Investigatory Powers Tribunal provides redress for individuals. Its existence is why error reporting matters: a material error — data disclosed that should not have been,

or disclosed about the wrong person — is reportable, and the design should make errors *detectable*, not merely unlikely.

2.6 Translating law into requirements

This table is the practical output of the module. It is deliberately written in the form you would put into a requirements traceability matrix.

Legal concept	Requirement it generates	Evidence that satisfies it
Necessity and proportionality	The system must not return more than the authorisation permits	Scope enforcement at query time; logged comparison of request scope to result scope
Entity vs events distinction	Every retained field must be classified, and the classification must drive access control	Data catalogue with per-field classification; query-time enforcement; sign-off record
Serious crime threshold (events)	Authorisation type must be checked before events data is released	Machine-readable authorisation attributes; enforced at the gateway
ICR restrictions (s.62)	ICR queries must be separately controlled and separately logged	Distinct capability, distinct audit stream, distinct approval
Content exclusion	The system must not disclose content, including content inferable from over-granular data	Documented content-boundary analysis per field; filtering; human review point
Retention limits (Part 4)	Automated, verifiable deletion at end of period	Deletion job with evidence; sampling; exception reporting
“Without undue delay”	Defined and monitored response times, with an urgent path	SLA instrumentation; separate urgent pipeline
s.11 lawful authority	The system must refuse to act on a request lacking valid authority	Authorisation validation; refusal is a designed, logged outcome
Oversight / inspection	Full reconstructability of every disclosure	Immutable audit; retention of the audit beyond the data
Error reporting	Errors must be detectable and reportable	Reconciliation controls; defined error taxonomy; escalation path
Notification notices	Notifiable-change detection in the release process	Change impact assessment with a capability-impact question

Key takeaways

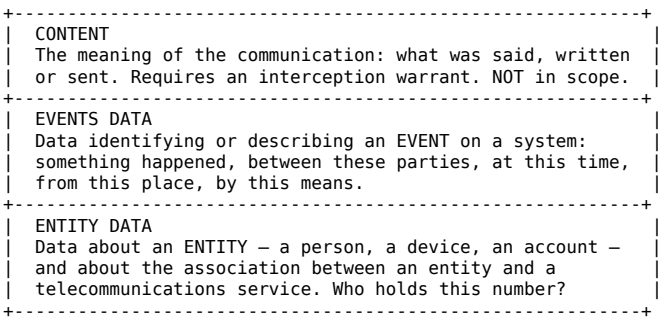
- Part 3 acquires, Part 4 retains, Part 9 compels capability. Know which one is generating the requirement in front of you.
- The entity/events distinction determines the legal test, so it must be a first-class, enforced attribute of the data model — not a documentation exercise.
- ICRs carry their own restrictions and their own political weight; treat them as a separate capability with separate controls.
- Notification notices make your own change process a regulated process.
- Oversight demands reconstructability. If a disclosure cannot be explained from system records years later, the design has failed even if it behaved correctly.

Module 3 — The Data Taxonomy [C/D]

> **Objectives.** You can classify a field as entity data, events data or content and justify the classification; you can explain why the boundary is difficult in an IP network; and you can specify the controls a design needs so that the classification is enforced rather than merely asserted.

If Module 2 is the map, this is the compass. Almost every hard question in a CDA design reduces to "which side of a line is this data on?"

3.1 The three categories



Entity data answers *who or what*. The subscriber behind a number; the account behind a username; the device associated with a SIM; the address a service is installed at; which services an account holds. It is comparatively static, and it is the less privacy-intrusive category — which is why the law permits it to be obtained on a lower threshold.

Events data answers *what happened, when*. A call was made from A to B at this time for this duration; a device registered on the network at this cell; a message was sent; a data session started and stopped. It is dynamic, it accumulates, and in aggregate it reveals pattern of life. The law therefore attaches the higher threshold to it.

Content is what was communicated. For a voice call, the audio. For a message, the text. And — the part designs get wrong — **anything that reveals the meaning of the communication**, including elements of signalling data that would disclose what a service was being used for at a level of detail beyond identifying the service itself.

3.2 Worked classification

The table below classifies the fields an IMS-era operator typically holds. Treat it as a worked example rather than an authority: your own classification must be made against the current Act and Code and signed off, and some of these are genuinely arguable.

Field	Classification	Note
Subscriber name and billing address	Entity	The classic “subscriber check”
MSISDN ↔ account mapping	Entity	
IMSI, IMEI associated with an account	Entity	
IMPI / IMPU associated with a subscription	Entity	The IMS-era equivalent
Services provisioned on an account	Entity	Voice, video, SMS, RCS
Account status, activation, cessation dates	Entity	Arguably event-like, generally treated as entity
IMS registration: identity, time, access type	Events	The device attached at this time
IMS registration: cell or access location	Events	Location is events data
Call/session start, end, duration, both parties	Events	The core record
Message sent: sender, recipient, time	Events	
Message body	**Content**	Never in scope
Media type of a session (voice vs video)	Events	Describes the event, not its meaning
Codec negotiated	Events, low value	Rarely worth retaining
Supplementary service invoked (forwarded, held)	Events	Useful and often overlooked
Forwarded-to number	Events	And a third-party data question
Data session start/stop, volume, IP and port	Events	
Destination IP/port or hostname of a session	Events, possibly ICR	**Depends on granularity — see §3.3**
Full URL beyond the host	Likely **content**	The classic bright line
DNS query for a hostname	Contested; often events/ICR	Jurisdiction- and design-sensitive
Cell site / location at a point in time	Events	
Device capability data (feature tags)	Entity or events by context	Often over-collected

> **Governance note.** Notice how many rows say “depends” or “arguably”. That is the honest position, and a design that presents this table with no ambiguity is concealing decisions rather than making them. The governance requirement is not that every field be obviously classified; it is that every arguable field have a **recorded decision, a named decision-maker and a stated rationale**. That record is what an inspector will ask for.

3.3 Where the content boundary actually bites

Three recurring cases. Each is a design decision dressed as a data question.

Granularity of a destination. “This device contacted `example.com`” identifies a service. “This device requested `example.com/support/bereavement-benefits/apply`” reveals the substance of the communication. Same protocol, same log source, different side of the line. The design consequence is that **truncation must happen at generation, not at disclosure** — if the full string is retained, it exists, and its existence is a risk and a disclosure target regardless of your intentions.

Signalling that carries meaning. Some signalling fields describe a service; others leak

substance. A SIP header identifying the communication service in use is descriptive. A subject line in a message header, or free-text carried in a signalling field, is content sitting in a place that looks like metadata. Anywhere an operator retains a signalling record verbatim rather than parsing defined fields out of it, this risk exists.

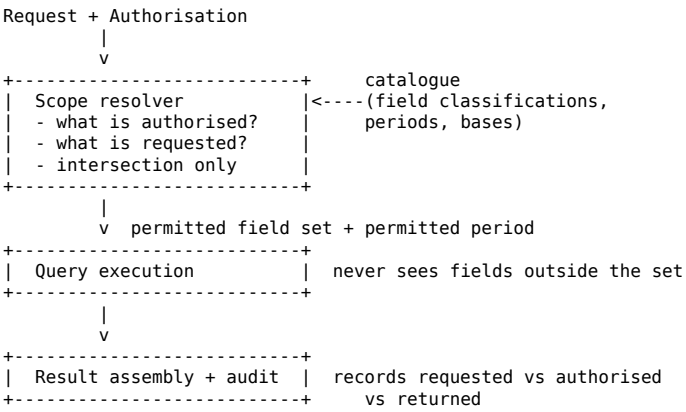
Inference from aggregation. A single record may be unambiguously events data while a long enough sequence of them discloses far more than any one of them. The law does not generally reclassify data because it was aggregated, but proportionality and oversight expectations bite harder on bulk-like queries. The practical design answer is to constrain the *query*, not only the *field*: limit periods, require the request scope to be enforced mechanically, and separately log broad queries for review.

3.4 Design controls the taxonomy demands

The taxonomy is not achieved by writing it down. Four controls make it real.

1. A field-level data catalogue as a build artefact. Every retained field carries: its classification, the legal basis for holding it, the retention period, its source system, its known quality characteristics, and the date and owner of the classification decision. This is a *machine-readable artefact used by the system*, not a spreadsheet in a governance folder — if the catalogue and the schema can drift apart, they will.

2. Classification-driven access control. The authorisation type carried with a request determines which classifications may be returned. An entity-only authorisation must be mechanically incapable of returning events data. This belongs at the query gateway, enforced, not in a user interface that a trained operator is expected to use correctly.



3. Truncation and parsing at the point of generation. Content-bearing granularity is removed before the record is written to the retention store. This is the single highest-value control in the whole architecture, because it converts a continuing risk into a one-off engineering decision.

4. A human review point with a defined remit. Somebody, with training and accreditation, looks at the result before it leaves — specifically for scope creep, content leakage and third-party data. The design decides *when* this is required: typically always for free-text or unparsed fields, and never for fully structured, pre-classified results. Making that rule explicit is better than making every disclosure wait for a human, which is what happens by default when nobody decides.

3.5 Third-party data

A request about A's communications necessarily reveals something about B, who is not the subject of any authorisation. This is unavoidable and is accepted in the regime — but it has design consequences:

- **Minimise incidental identification.** Return what the request needs, not the whole record because the whole record was easier to extract.

- **Flag it.** Results containing third-party identifiers should be marked so that handling downstream is deliberate.
- **Do not enrich it.** It is tempting to resolve the other party's number to a subscriber name because you hold that mapping. Unless the authorisation covers it, that is a fresh disclosure about a person who is not the subject. This is one of the most common real-world errors and it is designed in, not operator error, when the tooling enriches by default.

Key takeaways

- Three categories — entity, events, content — and the first two carry different legal thresholds, so classification has legal effect.
- The hard cases are granularity, signalling that carries meaning, and inference from aggregation.
- Classification must be enforced by the architecture: catalogue as a build artefact, scope resolution at the gateway, truncation at generation.
- Constrain the query as well as the field; proportionality lives in scope, not only in schema.
- Do not enrich third-party identifiers by default. Default-on enrichment is a designed-in error.

Part II — Where the Data Comes From

Module 4 — IMS as a Data-Producing Machine [C/D]

> **Objectives.** You can explain what IMS is in two minutes to a non-specialist, name the nodes that generate communications data and what each one knows, describe the records a call or message actually produces, and identify where the data you need is *not* generated.

Appendix C holds the protocol detail. This module is only concerned with what IMS produces, where, and how trustworthy it is.

4.1 IMS in two minutes

The **IP Multimedia Subsystem** is the standardised system operators use to deliver voice, video and messaging over packet networks. It is what makes a 4G or 5G phone call a phone call rather than an app: it supplies the telephone number as an identity, interconnect to every other operator, emergency calling, supplementary services such as diversion and barring, lawful process, and charging that can be reconciled between operators.

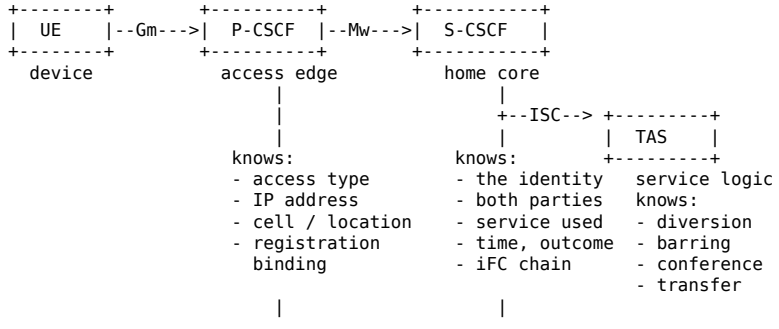
Three facts are enough to reason about the data.

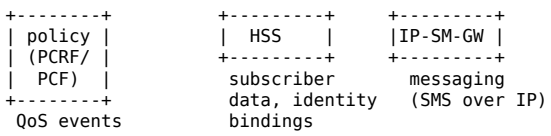
Fact 1 — signalling and media travel separately. The control messages that set up a call pass through the IMS core. The voice itself does not: it flows through the user plane, often bypassing the core entirely. **This is why communications data and content are physically separable in IMS** — a fortunate alignment between the architecture and the law, and the reason CD generation does not require touching media at all.

Fact 2 — the subscriber's home network always sees the transaction. However far the user roams, the session passes through their home serving node. So the home operator holds a record of every session its subscribers originate or receive, which is what makes CSP-side retention viable.

Fact 3 — IMS is access-independent. The same core serves 4G, 5G, Wi-Fi calling and fixed broadband. One consequence for design: the IMS record tells you the identity and the event, but tells you comparatively little about *where* — location comes from the access network, and must be correlated in.

4.2 The nodes that generate data, and what each knows





Node	Generates	Value for CDA
P-CSCF	Registration events, access type, UE IP address and port, cell identity via the access-network header, session start/stop as seen at the edge	**The location and access story.** The single richest source for "where was this device".
S-CSCF	Registration state, both parties' identities, session establishment and release, service invoked, final outcome	**The authoritative session record.** If you retain one thing, retain this.
TAS / MMTel AS	Supplementary service events: diversion applied, call waiting, transfer, conference, barring	The *why* behind an odd record. Frequently under-retained and then badly missed.
HSS	Identity bindings: IMPI, IMPUs, MSISDN, IMSI, service profile, current serving node	The entity-data backbone.
IP-SM-GW	SMS over IP send/deliver events and delivery reports	Messaging records when SMS runs over IMS rather than the legacy path.
IBCF / border	Interconnect events, peer operator identity, inter-operator identifiers	Who the other operator was; essential for onward enquiry.
SCC AS	Access transfers, domain selection decisions	Explains a session that moved between 4G, 5G and circuit-switched.
Policy (PCRF/PCF)	QoS session events tied to a media session	Corroboration and timing; rarely primary.
Charging (CDF/OCS)	The consolidated charging record	Often the *existing* production source the programme is tempted to reuse — see §4.5.

> **Governance note.** Ask early: *which node is the system of record for each event type, and what happens when two disagree?* In practice several nodes produce overlapping records of the same call, with different timestamps, different identifier forms and different completeness. A design that has not nominated a system of record per event type has deferred a problem that will surface as a data-quality incident under inspection.

4.3 What one voice call actually produces

A single answered call between two of your subscribers, in an ordinary IMS network, typically produces records at these points:

```
t0   Caller's device already registered      -> registration record exists
                                                (P-CSCF, S-CSCF)
t1   Session invitation submitted            -> originating session record
                                                starts (S-CSCF)
t2   Originating service logic applied       -> service event if barring,
                                                diversion etc. apply (TAS)
t3   Destination resolved, routed            -> interconnect record if the
                                                call leaves (IBCF)
t4   Terminating service logic applied       -> service event (TAS)
```

```
t5   Called device alerted                -> progress state
t6   Answered                             -> answer time recorded
t7   Media flows                          -> policy/QoS session record;
                                            NO content record
t8   Released                             -> release time, cause, duration
t9   Consolidated                         -> charging record(s) produced
```

So a single call yields several records from several systems, which must be correlated to produce the one row an investigator expects. That correlation is the central engineering problem of Module 8, and the thing most likely to be underestimated in a plan.

The equivalent for a message is shorter but has the same shape: a submit event, a routing event, a delivery event, and sometimes a delivery report — four records for one message, frequently in two different systems if SMS can travel either over IMS or over the legacy path.

4.4 What IMS does not tell you

An honest account of the gaps is more useful to a governance reader than a catalogue of the riches.

Question	Can IMS answer it?
Who called whom, when, for how long	**Yes**, well
Which identity was used	**Yes** — but several identities map to one person
Where the device was	**Partly** — via the access-network information carried in signalling, at cell granularity, at specific moments
Where the device was *between* events	**No** — that is access-network data, not IMS
What was said	**No**, and by design
Whether the call was answered by a person	**No** — answered is not answered-by-whom
Who the subscriber is	**No** — that is HSS and the business systems, joined in
What happened on a third-party app	**No** — OTT services are invisible to IMS
Whether a diverted call reached its final destination	**Only if** the diversion legs are retained and correlated
What device was used	**Partly** — device identity appears in registration, not reliably per session

The two entries in bold-adjacent territory are the ones that cause friction with acquiring authorities: continuous location, and anything about over-the-top services. Both are outside what the IMS record can honestly support, and the right governance response is to say so early and in writing rather than to let a requirement persist that the architecture cannot meet.

4.5 The charging-record temptation

Every programme reaches a moment where somebody says: *we already produce charging records; can we not just retain those?*

	Reuse charging records	**Purpose-built CD generation**
Cost to build	Low — the feed exists	High — new interfaces, new pipeline
Completeness	Only what is billable. Unanswered calls, zero-rated events, bundled traffic and internal transactions may be absent	Designed for the requirement

	Reuse charging records	Purpose-built CD generation
Timeliness	Batch, often hours; consolidated late	Can be near-real-time
Field set	Optimised for money, not for identity or location	Optimised for the request types
Stability	Changes whenever the tariff changes	Changes under change control
Classification	Mixed; not built with the entity/events boundary in mind	Classified by design
Evidential quality	Designed for internal reconciliation, not disclosure	Designed for provenance

The reuse option is often right for a first release, and is often *presented* as right for the end state. The governance question is not "which is better" but **"what does the notice actually require, and can this source meet it without a dependency on the billing roadmap?"** The dependency is the killer: tying a regulated capability to a commercial system whose changes are driven by marketing produces a permanent, invisible compliance risk.

> **Governance note.** If a design reuses charging records, insist on two artefacts: a **gap analysis** against the notice, field by field, with the gaps accepted explicitly; and a **change-coupling statement** naming who must be consulted before a billing change goes live. Without both, the risk is real and nobody owns it.

Key takeaways

- IMS separates signalling from media, so communications data can be generated without ever touching content — the architecture and the law agree here.
- Different nodes know different things: S-CSCF for the authoritative session, P-CSCF for access and location, TAS for why a call behaved oddly, HSS for identity.
- One call produces many records in many systems; correlation, not capture, is the hard part.
- IMS cannot give continuous location, anything about OTT services, or content — say so early.
- Reusing charging records is a legitimate first move and a dangerous end state; demand a gap analysis and a change-coupling statement.

Module 5 — Identifiers and the Resolution Problem [D]

> **Objectives.** You can enumerate the identifiers in play and say what each is good for; you can explain why identity resolution is the dominant design risk in CDA; and you can specify a resolution design that is defensible under inspection.

An acquiring authority arrives with one identifier and a time. Everything the system does afterwards depends on turning that into the right set of records about the right person — and on knowing when it cannot.

5.1 The identifier zoo

Identifier	What it names	Stability	Typical use in a request
MSISDN	The telephone number	Stable, but portable and reassignable	The most common starting point
IMSI	The subscription on the SIM	Stable per SIM	Links records across access and core
IMEI / IMEISV	The physical device	Stable per handset	"What else was used in this device?"
IMPI	The IMS private identity — the credential	One per subscription/device	Internal; rarely a request input
IMPU	The IMS public identity: a SIP URI or TEL URI	Several per subscriber	Appears throughout IMS records
IP address + port + time	A network endpoint at an instant	Highly unstable	Increasingly the starting point
Account number / customer ID	The commercial relationship	Stable	Entity-data enquiries
Username / handle	An account on a service	Varies	Where the operator runs the service
GRUU	A specific registered device instance	Per registration	Rare, but disambiguates multi-device

Two structural facts drive most of the difficulty.

A person is not an identifier. One person may hold several MSISDNs, several IMPUs aliased to each, a tablet with its own IMPI, and a Wi-Fi-calling registration from a device with no SIM at all. Conversely one MSISDN may have been held by three people over eighteen months.

Identifiers are reused. Numbers are recycled after cessation. IP addresses are reassigned continuously. IMEIs are cloned. **Therefore every identifier lookup is only valid with respect to a time**, and a design that resolves an identifier without a temporal qualifier is

producing confident answers about the wrong people. This is the single most consequential correctness requirement in the whole system.

5.2 The three resolution problems

```
(A) Identifier  ->  Subscriber          "who holds this number?"
    Entity data. Needs: time-qualified account history.

(B) Identifier  ->  Other identifiers    "what else is this person?"
    Entity data. Needs: binding history across MSISDN/IMSI/IMEI/IMPU.
    DANGER: over-expansion. Each hop widens the disclosure.

(C) Identifier + time  ->  Events        "what did they do?"
    Events data. Needs: correct resolution at (A)/(B) FIRST,
    then a scoped query.
```

Problem (B) is where designs go wrong in a way that matters. It is technically easy to walk the graph — this MSISDN was in this device, which also held that SIM, which is registered to that account — and each hop feels like the same enquiry. Legally, each hop may be a disclosure about a different person, and the authorisation may not cover it.

> **Governance note.** Require the design to answer: *how many hops does a resolution perform, is that number bounded, is the bound configurable per authorisation, and is the hop count in the audit record?* If the answer is "the tool follows the links", the design has delegated a legal judgement to a graph traversal.

5.3 Carrier-grade NAT, and why it breaks things

The IP-address-to-subscriber lookup is the case that most often fails in practice, and the reason is address sharing.

```
Subscriber A  10.x.x.x:...  \
Subscriber B  10.x.x.x:...   >-- CGNAT --> 203.0.113.7 : port ranges
Subscriber C  10.x.x.x:...  /
                              one public address, hundreds of subscribers
```

Given only a public IP address and a timestamp, the operator cannot say which subscriber it was. Resolution requires, at minimum, the **source port** and an **accurate time**, matched against the NAT translation records for that instant. That produces three hard design requirements:

1. **Port must be part of the request.** If the acquiring authority's source system does not capture source port, the enquiry is unanswerable and the design should return a clear "insufficient information" rather than a best guess. Getting this stated in the interface specification, rather than discovered case by case, saves an enormous amount of friction.
2. **Clock accuracy becomes a compliance control.** Translation bindings last seconds. A clock skew of a few seconds between the authority's source, the operator's NAT logs and the retention store turns a correct answer into a wrong one. Time synchronisation is therefore not an infrastructure detail in this system; it is a correctness control that belongs in the assurance regime with evidence attached.
3. **NAT logging volume is the dominant capacity driver.** Translation records vastly outnumber session records. Any capacity model that does not size this separately is wrong, usually by an order of magnitude.

Deterministic NAT allocation — giving each subscriber a fixed port range — reduces log volume by orders of magnitude at some cost in address efficiency. It is one of the highest-leverage design decisions available and is frequently made by the IP network team without reference to the CDA programme.

5.4 Designing resolution defensibly

Model bindings as intervals, not as facts. Every association — MSISDN-to-account, IMSI-to-MSISDN, IP-to-subscriber — is valid from a time to a time. The primary key of the resolution store is (identifier, type, valid-from, valid-to). Queries take a time and select the binding in

force. This sounds obvious and is very often not what the underlying business systems provide, because they hold current state and overwrite history.

```
Request: MSISDN=X, period 2026-02-01 .. 2026-02-28
                 |
                 v
+-----------------------------------------------+
| Binding store (interval model)                |
|  X -> account A   2024-06-01 .. 2026-02-14    |
|  X -> account B   2026-02-20 .. open          |
+-----------------------------------------------+
                 |
                 v
Result MUST distinguish:
  - 01 Feb .. 14 Feb : account A
  - 15 Feb .. 19 Feb : NOT ALLOCATED   <- say so explicitly
  - 20 Feb .. 28 Feb : account B       <- a different person!
```

That third row is the one that produces wrongful disclosure if the design returns “account B” for the whole period. **The requirement is that a resolution returns a time-segmented answer, including explicit gaps, not a single value.**

Return confidence, not just values. A resolution can be exact (a unique binding), ambiguous (several candidates, e.g. CGNAT without port), or absent. The interface must be able to express all three. Collapsing ambiguity into a single best answer is an error the receiving analyst cannot detect.

Separate resolution from retrieval. Resolution is an entity-data operation; retrieval of events is an events-data operation with a higher threshold. Keeping them as distinct services with distinct authorisation checks makes the legal boundary enforceable and the audit legible. Fusing them into one “search” is convenient and makes the entity/events distinction impossible to demonstrate.

5.5 Number portability and interconnect

Two more sources of wrong answers, both worth a governance question.

Portability. A number no longer identifies an operator. A request arriving at the wrong operator should produce a clear, standard “not our subscriber” response rather than an empty result — an empty result is indistinguishable from “no activity”, which is a materially different fact. Getting that distinction into the interface specification is a small change with large downstream value.

Interconnect. When the other party is on another network, you hold their number but nothing about them. Inter-operator identifiers in the records identify the peer operator, which tells the authority where to send the next enquiry. Retaining that field is cheap and disproportionately useful; it is also frequently dropped during pipeline design because it looks like routing minutiae.

Key takeaways

- Every identifier lookup is only valid with respect to a time; bindings are intervals, not facts, and the answer must be time-segmented with explicit gaps.
- Identifier-to-identifier expansion is a legal act per hop, not a graph traversal. Bound it, configure it per authorisation, and audit the hop count.
- CGNAT makes IP resolution impossible without source port and accurate time; say so in the interface specification and return “insufficient information” rather than a guess.
- Deterministic NAT allocation is a high-leverage decision usually taken outside the programme. Go and find out what was decided.
- Distinguish “not our subscriber” from “no activity”, and keep resolution and retrieval as separate, separately authorised services.

Module 6 — What the Data Can and Cannot Support [C/G]

> **Objectives.** You can set realistic expectations with an acquiring authority; you can explain the structural erosion of communications data and what it means for a ten-year investment; and you can frame the honest limitations of the capability in a way a governance board can act on.

This module exists because the commonest failure in CDA programmes is not technical. It is a requirement accepted that the data could never satisfy.

6.1 The four honest limits

1. The data describes the service, not the person. A record says that an identity used a service at a time. It does not say who was holding the device, whether the SIM was in its registered owner's phone, or whether the account holder was in the country. Every inference from identity to person is exactly that — an inference — and the CSP's disclosure should not present it as more.

2. Absence of a record is weak evidence of absence of an event. Records are missing for many innocent reasons: a node was restarted, a feed was late, a record failed validation, the service was carried by a path that does not generate a record, or the event was of a type never retained. A design must be able to distinguish *"we hold no record"* from *"we can confirm nothing happened"*, and must communicate that difference. Most cannot, and the gap is invisible to the recipient.

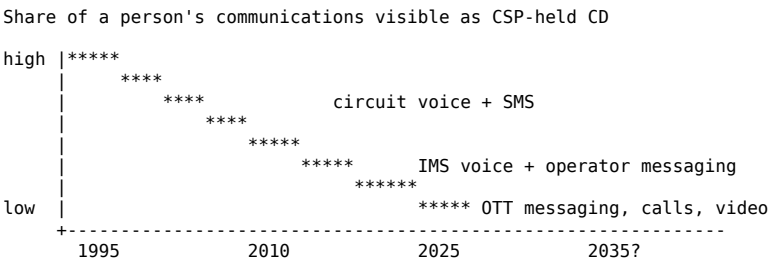
3. Timestamps are approximate and heterogeneous. Different nodes stamp at different points in a transaction, with different clocks and different conventions about what "start" means. Sub-second precision in a record is almost never sub-second accuracy across sources. Where timing matters — and in CGNAT resolution it decisively does — the design must state its accuracy, not its precision.

4. Location is coarse, occasional and inferred. IMS-era location is cell or access-point granularity, captured at the moments when signalling happens. It is not a track. Presenting a sequence of such points as a movement history invites over-interpretation, and the design can mitigate that by disclosing the uncertainty alongside the value.

> **Governance note.** These four limits belong in a written **capability statement** that the CSP maintains and the acquiring authority acknowledges. It is the artefact that prevents a slow drift into expectations the system cannot meet, and it is also, if an error ever reaches the Tribunal, the document that shows the operator described its capability honestly.

6.2 The erosion problem

The long-run trend is that the proportion of communications visible to a network operator falls. This is the single most important fact for anyone making a ten-year investment decision in this area.



The drivers:

- **Over-the-top services.** A message sent through a third-party application is, to the access operator, an encrypted data session to a cloud provider. The operator can say a session occurred; it cannot say to whom the user was speaking. That information, if it exists, sits with the application provider, who is frequently outside the jurisdiction.
- **Encryption in transport.** Encrypted DNS, encrypted SNI and QUIC progressively remove the fields that once let an operator identify the service being contacted, which is exactly the data that ICRs depend on.
- **Address sharing and privacy infrastructure.** CGNAT, VPNs, private relay services and IPv6 privacy addressing all weaken the identifier-to-subscriber link.
- **Flat-rate tariffs.** As Module 4 noted, the commercial reason to generate per-event records has gone, so records increasingly exist only because they are compelled.

The governance consequence is not that the capability is pointless — the data that remains is high value, particularly identity resolution and the service usage the operator does carry. It is that a business case which assumes constant or growing evidential yield is wrong, and that the right architectural posture is *modularity*: assume the sources change, and do not couple the retention schema, the query model and the handover interface so tightly that replacing a source means rebuilding the system.

6.3 What remains valuable, and is often under-exploited

Against that erosion, four things get *more* valuable, and they are worth naming because programmes tend to spend disproportionately on the eroding half.

Capability	Why it holds its value
Identity resolution	Every other line of enquiry starts here, and only the operator can do it. Resilient to encryption.
Registration and attachment events	A device attached to this network at this time in this place — unaffected by what it then did.
Service-layer events on operator-run services	Where the operator *is* the service (IMS voice, operator messaging, RCS), the records remain complete.
Corroboration and pattern	Even without content or destination, the shape of usage corroborates or contradicts an account.

6.4 Setting expectations in practice

Three artefacts do most of the work, and all three are cheap relative to their effect.

A data availability matrix. For each request type, what the operator can return, at what granularity, for what historical period, and with what known caveats. Published to the acquiring authority and version-controlled.

Request type	Available	Period	Granularity	Caveats
Subscriber for MSISDN	Yes	Account life + N	Exact	Time-segmented; gaps shown
Subscriber for IP + port + time	Yes	12 months	Exact if port supplied	Unanswerable without port; ±N s clock
Voice session records	Yes	12 months	Per session	On-net complete; off-net leg limited
Operator messaging	Yes	12 months	Per message	Delivery status where produced
Location at session time	Yes	12 months	Cell	Occasional, not continuous
OTT service identification	**No**	—	—	Encrypted; out of scope
Continuous location	**No**	—	—	Not generated

A defined “nil return” vocabulary. Distinct, documented responses for: not our subscriber; identifier not allocated in this period; no records held for this period; insufficient information to resolve; request outside authorised scope. Five responses, five different meanings, and collapsing them into “nothing found” destroys information the recipient needs.

A caveat that travels with the data. Every disclosure carries its own provenance and limitation statement, so that the caveat cannot be separated from the result as it moves through the recipient’s systems.

Key takeaways

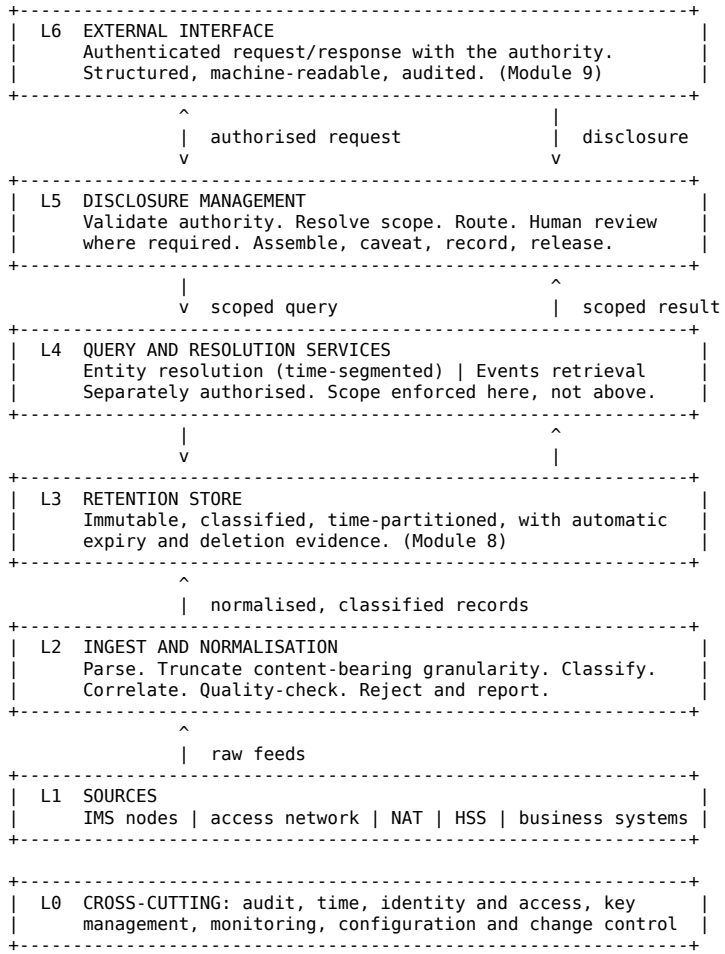
- The data describes the service, not the person; absence of a record is not absence of an event; timestamps are approximate; location is occasional.
- Operator-visible communications data is structurally eroding. Design for modular replacement of sources, and do not build a business case that assumes constant yield.
- Identity resolution, attachment events and operator-run service records are the parts that hold their value.
- Three cheap artefacts — availability matrix, nil-return vocabulary, travelling caveats — prevent most expectation failures.

Part III — Designing the Solution

Module 7 — Reference Architecture for a CSP Disclosure Capability [D]

> **Objectives.** You can draw and justify a layered reference architecture for the CSP side; you can state the responsibility of each layer and the interface between them; and you can identify the three architectural decisions that determine whether the system will still be viable in ten years.

7.1 The reference architecture



The layering is not decoration. Each boundary is where a specific kind of control is applied, and collapsing any two of them removes a control:

Boundary	Control applied there
L1 → L2	Content truncation and field parsing — *the irreversible one*
L2 → L3	Classification and quality gating; nothing unclassified is stored
L3 → L4	Retention period enforcement; expired data is not queryable
L4 → L5	Scope enforcement: authorisation intersected with request
L5 → L6	Human review, caveat attachment, release authorisation

> **Governance note.** When reviewing a vendor architecture, map it onto these six layers and ask where each control lives. Products frequently merge L4 and L5 — a single "investigation workbench" — which puts scope enforcement and result assembly in the same component as the user interface. That is not automatically wrong, but it means scope is enforced by the application the user is driving rather than by a service beneath them, and the audit story changes accordingly.

7.2 Layer responsibilities in detail

L1 — Sources. Not built by the programme, but constrained by it. The key governance act here is establishing, per source, a **data supply agreement**: what is produced, at what completeness, with what timing, and who must be consulted before it changes. Without this, a routine network upgrade silently changes a retained field's meaning.

L2 — Ingest and normalisation. The most underestimated layer. It performs:

- parsing of source records into defined fields;
- **truncation of content-bearing granularity — before storage, irreversibly**;
- classification of every field against the catalogue;
- normalisation of identifiers into canonical forms (E.164, URI forms);
- time normalisation to a single reference with recorded source accuracy;
- correlation of the several records for one event into a correlated set;
- validation, with rejected records counted, reported and retained separately for diagnosis.

L3 — Retention store. Module 8.

L4 — Query and resolution. Two distinct services, deliberately:

```
Entity Resolution Service        Events Retrieval Service
-------------------------        ------------------------
input: identifier + period       input: resolved identity set + period
                                        + authorised field classes
output: time-segmented           output: scoped record set
        bindings + confidence            + completeness statement
threshold: entity                threshold: events (higher)
```

L5 — Disclosure management. The workflow layer, and the place where the human sits. Responsibilities: validating that the authority cited is present, current and covers what is asked; resolving the authorised scope; dispatching to L4; applying the review rule; assembling the response with provenance and caveats; recording everything; releasing.

L6 — External interface. Module 9.

L0 — Cross-cutting. Audit, time, access control, keys, monitoring and change control. Treated as a layer because in this domain they are functional requirements with legal force, not non-functional afterthoughts.

7.3 The three decisions that determine longevity

Most architectural choices in this domain are recoverable. Three are not, and they deserve explicit design-authority decisions with recorded rationale.

Decision 1 — Where is content-bearing granularity removed?

Option	Consequence
At generation, in the source	Cleanest. The data never exists. Requires network-element capability and cooperation; may be impossible with COTS elements.
At ingest (L2), before storage	The standard answer. The full value exists transiently in the pipeline, so the pipeline itself becomes a controlled environment.
At disclosure (L5)	Weakest. The content-bearing value is retained for months and is a standing risk and disclosure target. Avoid; if forced, document why and compensate with access controls.

Decision 2 — Is retention a copy or the system of record?

Option	Buys you	Costs you
Dedicated retention store, fed from production	Isolation; independent lifecycle; classification by design; production changes do not directly break compliance	Duplication; reconciliation burden; cost
Query production systems on demand	No duplication; always current	Production performance risk; no independent retention control; deletion cannot be guaranteed; change coupling

Practically, the dedicated store wins for anything under a retention notice. The interesting variant is *hybrid*: a dedicated store for compelled retention, with on-demand access to production for data held on other bases. That hybrid is defensible but requires the boundary to be explicit, because the two halves have different legal bases and different permitted uses.

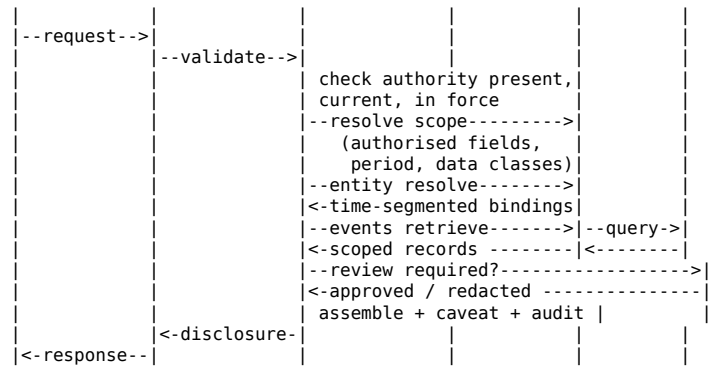
Decision 3 — How is scope enforced?

Option	Assurance strength
Procedurally — trained staff apply the authorisation	Weakest. Depends on human consistency; hard to evidence; fails under volume
In the application — UI restricts what can be asked	Moderate. Bypassable by anyone with data-layer access
In a scope-resolution service beneath the application	Strong. Every query carries a machine-readable authorisation; the service intersects and enforces; the audit records requested/authorised/returned
In the data layer — row and column security bound to the authorisation	Strongest, hardest to build, least flexible

> **Governance note.** This is the decision that most determines whether an inspection goes well. “We trained our staff” is a materially weaker answer than “the system could not have returned that, and here is the log of the intersection it computed.”

7.4 A sequence through the architecture

```
Authority    L6 iface    L5 disclosure   L4 query    L3 store   Reviewer
```



Note what is *not* in that sequence: no step in which a human decides what the query should be. The request and the authorisation determine it. The human decides whether the *result* may be released. That division — machine determines scope, human approves release — is the one that both scales and survives inspection.

Key takeaways

- Six layers, five boundaries, and each boundary carries a named control. Collapsing a boundary removes a control.
- Ingest and normalisation is the layer most often underestimated and the one where the irreversible content decision is taken.
- Keep entity resolution and events retrieval as separate, separately authorised services; that is what makes the legal boundary demonstrable.
- Three non-recoverable decisions: where truncation happens, whether retention is a copy or the system of record, and how scope is enforced.
- Machine determines scope from the authorisation; human approves release.

Module 8 — Designing the Retention Store [D]

> **Objectives.** You can specify a retention store against a notice; you can reason about the correlation problem, the partitioning and deletion model, and the capacity drivers; and you can challenge a capacity plan credibly.

8.1 Requirements the notice generates

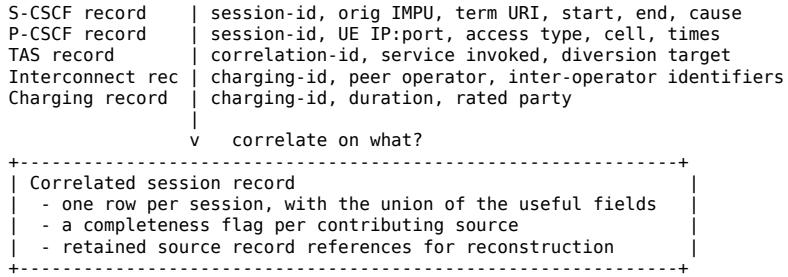
A data retention notice is the requirements baseline. Translated:

From the notice	Design requirement
Specified data types	An explicit, versioned schema; anything not in it is not retained
Up to 12 months	Per-record expiry, enforced automatically, with evidence
Integrity and security obligations	Immutability, access control, encryption, monitoring
Disclosure “without undue delay”	Defined query performance targets, plus an urgent path
Destruction at end of period	Verifiable deletion, including from backups and indexes
Same standard as business data	It is not acceptable for the compelled store to be less well run than the commercial ones

> **Governance note.** “Verifiable deletion including from backups” is the requirement most often quietly unmet. Ask directly: what is the backup retention period, does it exceed the data retention period, and if so what is the mechanism that prevents expired data being restored? An honest answer is often “we have not solved that yet”, which is a finding worth having.

8.2 The correlation problem

Module 4 established that one call produces several records in several systems. The retention store must present *one* coherent view.



The correlation key is the crux. Options, with their trade-offs:

Key	Strength	Weakness
Charging identifier carried across nodes	Designed for exactly this; survives service logic that changes the session	Only present where charging is engineered through; may be absent on non-billable events
Session identifier from signalling	Always present	Changes at any node that terminates and re-originates the session — service logic does this routinely, so legs fragment
Time + identifier heuristics	Works with anything	Fragile, produces false joins, indefensible under challenge

The right answer is nearly always the charging identifier where it exists, with explicit, recorded handling of the cases where it does not — and **never** silent heuristic joining. A heuristic join that is right 99% of the time produces wrong disclosures about real people in the other 1%, undetectably.

Design for partial correlation. Some contributing records will be late, missing or unmatched. The store should hold the correlated record *with a completeness indicator per source*, rather than waiting for perfection or discarding the fragment. That indicator then travels into the disclosure as part of the caveat, which is exactly the honesty Module 6 demanded.

8.3 Data model shape

Three families, with different characteristics and, usefully, different retention arguments:

```
ENTITY / BINDING STORE          EVENTS STORE              RESOLUTION AIDS
----------------------          ------------              ---------------
interval-keyed                  time-partitioned          NAT translations
(identifier, type,              append-only               DHCP / RADIUS
 valid_from, valid_to)          immutable                 huge volume
low volume, high value          high volume               short life
updated by change events        never updated             different sizing
entity classification           events classification     events class.
```

Keeping them physically separate is worth doing for four reasons: they have different volumes by orders of magnitude; different retention periods are often justified; the entity/events access control boundary becomes a physical boundary rather than a logical one; and the resolution aids can be sized, tuned and — if the law allows — expired independently.

Every record carries: its classification, its source, its ingestion time, its expiry time, and a reference sufficient to reconstruct its derivation. That last field is what makes the store auditable rather than merely queryable.

8.4 Partitioning, expiry and deletion

Time partitioning is not an optimisation here; it is the deletion mechanism.

```
Partition by ingest day (or hour, for the highest-volume feeds)

[ d-365 ][ d-364 ] ..................... [ d-1 ][ d-0 ]
   ^                                         ^
   |                                         |
expiring today:                           writing
- detach partition
- cryptographically erase or securely destroy
- record: partition id, record count, timestamp,
  operator, verification hash
- remove from indexes
- confirm absence from backup sets in scope
```

Three refinements that separate a good design from a compliant-looking one:

- **Deletion produces evidence.** A deletion job that leaves no artefact cannot be inspected. The evidence record — what was deleted, how many, when, verified how — must itself be retained *longer* than the data, because it is the proof that the obligation was met.
- **Legal hold is a designed feature, not an exception.** Where data is subject to ongoing proceedings, it must be exemptable from expiry, and that exemption must be authorised, time-bounded and reviewed. Designs that lack this end up suspending the deletion job, which suspends it for everything.
- **Crypto-shredding as the practical answer to backups.** Where per-partition keys are used, destroying the key makes the data unrecoverable everywhere it has been copied. This is usually the only workable answer to the backup problem, and it drives a key management design with real obligations.

8.5 Capacity — and how to challenge a plan

Five drivers, in descending order of how often they are underestimated:

1. **NAT / translation records.** Typically the largest by far. Sized by sessions per subscriber per day, not by calls. Deterministic allocation changes the number by orders of magnitude.
2. **Registration and attachment events.** Devices re-register more often than people imagine, and IoT populations behave nothing like handsets.
3. **Messaging events.** Including delivery reports, which double the count.
4. **Correlated session records.** The one everyone sizes, and usually the smallest.
5. **Indexes.** Frequently as large as the data, and often omitted entirely from the plan.

Questions that expose a weak capacity plan:

- What is the assumed ratio of translation records to session records, and where did it come from — measurement or assumption?
- Does the model include indexes, replicas and the correlated copy, or only raw record volume?
- What happens at the 12-month boundary — is steady state modelled, or only the growth curve?
- What is the assumed query concurrency, and what is the *urgent* query performance under the *worst-case* concurrent load?
- How does the model behave if an IoT or fixed-wireless population is added mid-life?
- What is the re-ingest cost if a classification decision changes and records must be re-derived?

That last one is worth dwelling on. Classification decisions do change, and a store that cannot be re-derived from retained source references means the only options are "leave it wrong" or "lose the history". Designing for re-derivability is cheap at the start and impossible to retrofit.

8.6 Quality controls at ingest

Control	What it catches
Schema validation	Source change, corrupt records
Referential checks on identifiers	Malformed or unresolvable identities
Volume reconciliation against source counts	Silent feed loss — **the most common serious fault**
Time-window completeness	Late and missing batches
Duplicate detection	Replay, double ingestion
Classification coverage	Any field arriving that the catalogue does not know
Clock drift monitoring	The correctness control from Module 5

Volume reconciliation deserves emphasis. A feed that stops produces no errors — it produces silence, and silence looks exactly like a quiet period. A store can lose a source

for weeks without any alarm unless expected volumes are independently compared against source-side counts. Every disclosure made in that window is potentially incomplete and nobody knows. If you take one operational control from this course, take this one.

Key takeaways

- The notice is the schema's requirements baseline; retain what it specifies and nothing more.
- Correlate on a charging identifier where one exists; never silently join on heuristics; carry a per-source completeness indicator into the disclosure.
- Separate entity, events and resolution-aid stores physically — different volumes, different periods, different access boundaries.
- Time partitioning is the deletion mechanism; deletion must produce evidence that outlives the data; crypto-shredding is usually the only real answer to backups.
- Volume reconciliation against source counts is the control that catches the failure nothing else will.

Module 9 — Request Handling, Mediation and Handover [D/G]

> **Objectives.** You can specify the interface between an acquiring authority and a CSP; you can explain the relevant ETSI standards and what each is for; and you can design the assurance controls that make the interface trustworthy to both parties.

This is the module about the seam — and the seam is where most of the residual risk in a CDA capability lives, because it is the only part neither party wholly controls.

9.1 What the interface has to carry

```
Acquiring authority                          CSP
-------------------                          ---
Request:                                     Response:
  - reference / case identifier                - status
  - authorisation reference and attributes     - the data
  - requester and SPoC identity                - completeness statement
  - data sought (types, classes)               - caveats and provenance
  - identifier(s) and time period              - handling markings
  - urgency                                    - cost/charging reference
  - delivery destination                       - errors and nil reasons

Plus, in both directions:
  - acknowledgement, status updates, clarification, withdrawal,
    error signalling, and a complete audit of every exchange
```

Two design principles that follow directly.

The authorisation must be machine-readable. If the authority's scope arrives as free text in a covering note, then scope enforcement (Module 7, Decision 3) can only be procedural, and every downstream assurance claim weakens. The interface should carry the authorisation's *attributes* — type, purpose, data classes permitted, period, expiry — as structured fields.

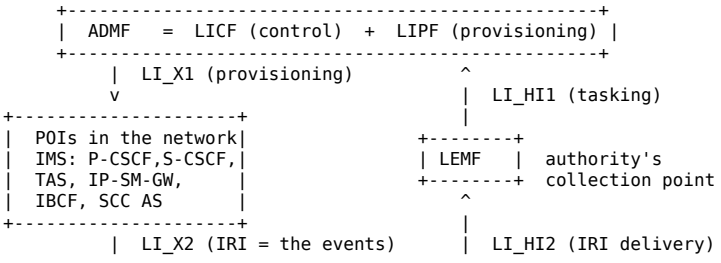
The interface must express partial and negative outcomes richly. Module 6's nil-return vocabulary lives here. An interface that can only say "results" or "no results" forces the CSP to discard information the authority needs.

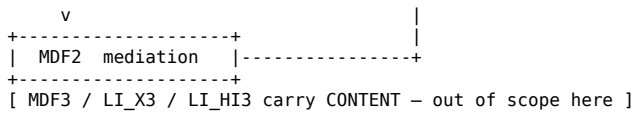
9.2 The standards landscape

Standard	What it is	Where it fits
ETSI TS 103 120	"Interface for warrant information" — a structured, extensible interface for conveying authorisations and tasks between authorities and operators, and for status and delivery notifications. XML/JSON over HTTPS, with objects for Authorisation, Document, Task, Notification and Delivery. Actively maintained; recent versions through 2025.	The **request/authorisation** interface — the modern replacement for email and bespoke portals
ETSI TS 102 657	Handover interface for the request and delivery of **retained data**. Defines the requesting interface (often written HI-A) and the delivery interface (HI-B), with data structures for subscriber, telephony, messaging and network access records.	The **retained-data delivery** model and schemas
ETSI TS 102 232 series	Handover specification for IP delivery, widely used as the delivery transport mechanism.	Delivery transport
3GPP TS 33.126 / 33.127 / 33.128	Lawful interception requirements, architecture and stage-3 for 3GPP networks, including IMS. Defines ADMF (LICF + LIPF), POIs, MDFs and the LI_X and LI_HI interfaces.	The **network-side architecture** the CSP's capability must fit into
3GPP TS 33.108	The older handover specification, still encountered in legacy estates.	Legacy

A crucial framing point for governance: the 3GPP LI architecture was designed for interception, and communications data acquisition reuses much of its plumbing. **The same architecture carries both content and communications data; the separation is achieved by authorisation and provisioning, not by physics.** That is an uncomfortable fact worth stating explicitly in a design paper, because it means the controls that keep the two apart are administrative and must therefore be exceptionally well evidenced.

9.3 The 3GPP architecture, at governance level





Three governance observations:

- **The ADMF is the crown jewel.** Whoever controls provisioning controls what is intercepted and what is disclosed. Its access control, change control and audit are the highest-assurance components in the estate, and they should be reviewed as such rather than as ordinary management systems.
- **The mediation function is where policy becomes bytes.** MDF2 decides what is actually delivered and in what form. Filtering, formatting and caveating happen here or nowhere.
- **The X3/HI3 path exists whether or not you use it.** If the capability is CD only, demonstrate — do not assert — that the content path is not provisioned, and make that demonstrable state part of the assurance evidence.

9.4 Designing the interface: decisions

Synchronous or asynchronous?

Option	Right when
Synchronous request/response	Simple, high-volume, fully automatable enquiries — a subscriber check against the binding store
Asynchronous submit / poll or callback	Anything requiring human review, long-running retrieval, or large results — the majority
Both, by request type	The practical answer. Publish which types are which.

How is the response delivered?

Option	Considerations
Inline in the response	Simple; bounded by size; fine for entity data
Separate delivery channel (e.g. TS 102 232 style)	Standard for bulk results; separates control from data; adds a second channel to secure and audit
Retrieval from a portal	Convenient; weaker automation; audit lives in two places; avoid as the primary mechanism

Who resolves ambiguity?

The most consequential and least-discussed interface decision. A request may be ambiguous — an identifier that resolves to several candidates, a period that spans a reassignment, a data type that does not exist in this network.

Option	Consequence
CSP resolves and returns its best interpretation	Fast; but the CSP is making a judgement it has no authority to make, and the authority cannot see it happened
CSP returns the ambiguity and the authority decides	Slower; correct; keeps the legal judgement with the body that holds the authorisation

Option	Consequence
CSP returns all interpretations	Over-discloses; may exceed scope

The middle option is nearly always right, and it requires the interface to have a **clarification exchange** — a first-class message type, not an email. Designs that lack one push the exchange into an unaudited channel, which is where the audit trail breaks.

> **Governance note.** Ask to see the interface specification's message catalogue. If it has "request" and "response" and nothing else, it will fail in operation and the gaps will be filled by telephone calls and email — with the corresponding loss of audit. A usable catalogue has at least: submit, acknowledge, clarify, amend, withdraw, status, deliver, error, nil-return.

9.5 Securing the seam

Control	Purpose
Mutual authentication of both endpoints	Neither party acts on an unauthenticated instruction
Per-request non-repudiation — signed requests and signed responses	Years later, both parties can prove what was asked and what was sent
Dedicated, segregated connectivity	Reduces exposure; simplifies the assurance case
Independent audit at both ends, reconcilable	Either party can detect tampering or omission by comparing
Rate and volume anomaly detection	Detects compromise of the authority's endpoint — an unusual but high-impact scenario
Cryptographic integrity over delivered data	Underpins evidential weight (Module 11)
Key management with defined rotation and revocation	Otherwise the above degrades quietly

The reconciliation point deserves emphasis. If both parties keep independent, comparable records of every exchange, then a discrepancy is detectable. If only one does, the other is trusting it. Building reconcilable audit at both ends is the strongest single assurance control available at the seam, and it costs little if designed in.

9.6 Urgent requests

Threat-to-life and similar cases need an answer in minutes, and the design must accommodate that without weakening the controls.

```
Normal path:  submit -> validate -> queue -> retrieve -> review -> release
              minutes to hours, human review, full assembly

Urgent path:  submit -> validate -> retrieve -> release
              target minutes; pre-agreed narrow scope;
              review AFTER release, not before;
              automatic escalation and 100% post-hoc audit
```

The design decisions that make the urgent path defensible:

- **Narrow it.** The urgent path supports a small, pre-agreed set of request types — typically identity resolution and recent location — not everything.
- **Move the human, do not remove them.** Review happens after release, within a defined period, and every urgent disclosure is reviewed, not sampled.
- **Make it visibly different.** Distinct audit stream, distinct reporting, distinct reconciliation with the authority. If urgent volumes rise, that is a governance signal, and it should be visible without anyone running a query.

- **Rehearse it.** An urgent path that has never been exercised out of hours will not work at 3 a.m.

Key takeaways

- The interface must carry machine-readable authorisation attributes, or scope enforcement can only ever be procedural.
- TS 103 120 for request and authorisation, TS 102 657 for retained-data structures and handover, TS 102 232 for delivery transport, 3GPP 33.127/128 for the network-side architecture.
- The same architecture carries content and communications data; separation is administrative, so its evidence must be exceptional.
- Ambiguity belongs with the authority, which means the interface needs a first-class clarification exchange.
- Reconcilable audit at both ends is the strongest control at the seam; signed requests and responses are what make it work years later.

Module 10 — Security, Compartmentation and Insider Risk [D/G]

Objectives. You can articulate the threat model for a CDA capability; you can design the compartmentation and access model; and you can identify the insider-risk controls that the regime effectively requires even where it does not name them.

10.1 The threat model, stated honestly

A CDA capability is a concentrated, high-value target with an unusual property: **its most damaging misuse looks exactly like its intended use.** A query run for a personal reason is technically identical to one run for an investigation. That shapes everything.

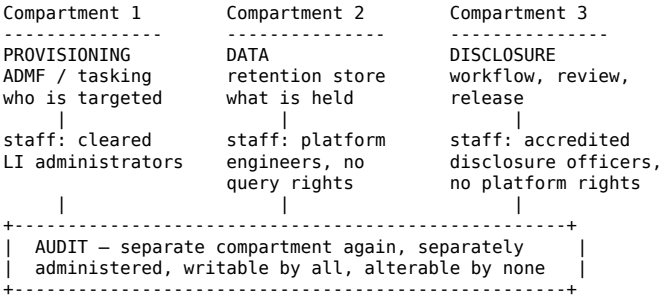
Threat	What it looks like	Primary control
Insider misuse	A legitimate user runs an unauthorised query	Scope binding to authorisation; anomaly detection; proactive audit
Insider exfiltration	Bulk extraction by someone with legitimate access	Volume controls; egress monitoring; separation of duties
Compromise of the authority's endpoint	Well-formed requests arriving with valid credentials for fabricated cases	Reconcilable audit; anomaly detection; out-of-band verification for unusual patterns
Compromise of the CSP estate	Attacker reaches the retention store	Segregation; encryption; strong isolation from the corporate estate
Compromise of the provisioning function (ADMF)	Attacker tasks the network	Highest-assurance controls; dual authorisation; immutable audit
Supply chain	Vendor access, remote support, software updates	Vendor access model; code provenance; controlled update path
Legal/process failure	Correct system, invalid authority	Machine validation of authority; refusal as a designed outcome
Aggregation by a hostile state	Long-term, low-and-slow collection	Compartmentation; detection over long windows

Governance note. The threat that a board will not raise, and that you should, is the third one: a compromised or coerced endpoint at the *authority*. The CSP's controls largely assume requests are genuine. Ask what would detect a run of plausible, well-formed, individually unremarkable requests that were not in fact authorised. In

most designs the honest answer is “reconciliation with the authority’s own records, if anyone ever does it” — which is an argument for doing it routinely and automatically.

10.2 Compartmentation

The organising principle: **no single person, and no single system component, should be able to go from “I want to know about X” to “here is everything about X”.**

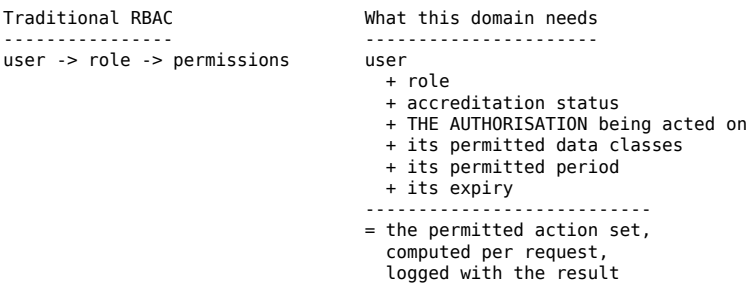


Four rules that make this real rather than nominal:

1. **Platform engineers must not be able to run disclosure queries.** They can keep the store running; they cannot ask it questions about people. This usually requires the query path to be the *only* path to plaintext, with platform access limited to encrypted storage and metadata.
2. **Disclosure officers must not be able to change the system.** No configuration, no schema, no scope rules.
3. **Nobody administers their own audit.** The audit compartment is administered by a separate authority — often internal audit or a security function with no operational role.
4. **Privileged actions require two people.** Provisioning a target, changing a scope rule, exporting in bulk, suspending deletion, or granting access.

10.3 Access control that matches the law

Ordinary role-based access control is insufficient here, because the question is not “what may this user do?” but “what may this user do *in respect of this authorisation*?”



The practical implication: **access decisions are per-request, not per-session, and the authorisation is an input to the access decision.** A user logged in with a valid role and no live authorisation can do nothing. This is more work than standard RBAC and it is the mechanism that makes “the system could not have returned that” true rather than aspirational.

Accreditation as an attribute. In the UK model, disclosure staff and SPoCs are accredited. Accreditation lapses. Making it a checked attribute rather than an HR record means a lapsed accreditation removes capability automatically, which is both better control and one less thing for an inspection to find.

10.4 Encryption and key management

Where	What	Why it matters here
In transit, external	Mutual TLS, plus signing at the message layer	Confidentiality *and* non-repudiation
In transit, internal	Encrypted between all layers	Limits lateral movement
At rest, bulk	Per-partition keys	Enables crypto-shredding at expiry (Module 8)
At rest, sensitive fields	Field-level encryption for direct identifiers	Platform staff can operate the store without reading it
In use	Where available, confidential computing for the query path	Reduces the trusted footprint; still maturing
Key custody	Split across compartments; HSM-backed	The keys are the control; if one team holds all of them, compartmentation is nominal

The key management design is where several of the obligations meet: deletion evidence, compartmentation, and the ability to prove that platform staff could not have read what they administered. It deserves a design paper of its own and usually does not get one.

10.5 Detecting misuse

Preventive controls fail; the regime expects detection too.

Control	Detects
Query-to-authorisation reconciliation	Queries with no valid authority behind them
Volume and pattern anomaly detection per user	Fishing, bulk extraction, gradual abuse
Subject-of-interest alerting	Queries about staff, public figures, or protected categories
Self-query and associate-query detection	The classic insider pattern: looking up oneself, family, neighbours, ex-partners
Out-of-hours and unusual-context flags	Access outside the operational pattern
Proactive sampling audit	A defined percentage reviewed regardless of suspicion
Reconciliation with the authority's records	Fabricated or altered requests

Self-query detection is the highest-yield control per unit of effort. It is trivially implementable — compare the query subject against the staff identifier set and their known associates — and historically it is the pattern that most real insider incidents in comparable systems have followed.

10.6 Vendor and supply chain

Three questions that should be settled before contract, not after:

- **Can the vendor reach production, and under what conditions?** Standing remote access into a CDA estate is very hard to defend. The alternative — supervised, time-bounded, recorded, break-glass access — is more expensive to operate and far easier to assure.
- **What does the vendor's software do that you cannot see?** Closed components in the query or mediation path mean the assurance case rests on the vendor's assertions. Source availability, reproducible builds, or at minimum contractual audit rights, change the shape of that case.
- **What happens at end of life?** These systems outlive their vendors' product lines. Data portability and schema ownership are compliance issues, not commercial ones: if you cannot migrate the retained data, you cannot meet the notice with a different supplier.

Key takeaways

- The defining property of this threat model is that misuse looks exactly like use; that forces detection controls alongside preventive ones.
- Compartmentation means provisioning, data, disclosure and audit are separately staffed and separately administered, with two-person control on privileged actions.
- Access control must take the authorisation as an input and decide per request, not per session; accreditation should be a checked attribute.
- Per-partition keys serve deletion, compartmentation and the proof that platform staff could not read the data.
- Self-query and associate-query detection is the cheapest high-yield control in the whole design.

Part IV — Assurance and Governance

Module 11 — Quality, Integrity and Evidential Weight [G]

Objectives. You can specify the assurance regime for a CDA capability; you can explain what makes disclosed data evidentially usable and what destroys that; and you can design the error and reporting model the regime expects.

11.1 Three different standards, often confused

Standard	Question it answers	Who needs it
Data quality	Is the data accurate, complete and timely?	Everyone, always
Data integrity	Can we prove it has not changed since it was created?	Anything that may be relied on later
Evidential weight	Will a court accept it, and how much will it carry?	Only the subset that reaches proceedings

Designs commonly conflate the second and third and then either over-engineer everything or under-engineer the part that matters. The useful discipline is to decide, explicitly, which disclosures are built to evidential standard. In most operators the honest answer is *all of them*, because you cannot know in advance which will be used — and that answer should be reached deliberately, with its cost accepted, rather than by default.

11.2 What evidential weight actually requires

Not a legal treatment, but the engineering properties that support it:

Provenance. For every disclosed value: which source system produced it, when, through which processing steps, under which version of the transformation logic. "This field came from the S-CSCF record ingested at T under pipeline version 4.2" is a provenance statement; "this came from our retention system" is not.

Integrity. The disclosed data can be shown not to have changed between generation and presentation. Practically: hash at ingest, hash the retained record, hash the disclosure, sign the disclosure, and retain the chain.

Repeatability. The same query against the same data returns the same result. This is harder than it sounds where correlation is involved — a correlated record assembled from late-arriving components may legitimately differ between two runs, which is precisely why the *as-at* time of the disclosure must be recorded and why the correlated record should be immutable once assembled.

Explicability. A competent witness can explain how the system produced this answer. That is a constraint on *design*, not on documentation: a pipeline with undocumented heuristics, machine-learned matching, or emergent behaviour produces answers nobody can explain in

a witness box. This is the strongest argument against the heuristic correlation warned about in Module 8.

Continuity. The chain of custody from generation to presentation is unbroken and recorded, including every human who handled the data.

> **Governance note. The explicability constraint is an architectural veto.** It rules out design options that would otherwise be attractive — probabilistic identity matching, opaque third-party enrichment, adaptive heuristics. If a vendor proposes any of these in the resolution or correlation path, the question is not "how accurate is it?" but "who will explain it, and what happens when they cannot?"

11.3 The quality framework

Six dimensions, each with a measure, a target and a reporting line. This is the table to put in the assurance strategy.

Dimension	Measure	Typical control
Completeness	Records received vs records expected, per source per period	Volume reconciliation against source counts
Accuracy	Sampled records verified against source	Periodic sampling with independent verification
Timeliness	Generation-to-availability latency distribution	Monitored per feed with alerting on the tail
Consistency	Agreement between overlapping sources for the same event	Cross-source comparison on a sample
Validity	Conformance to schema and to identifier formats	Validation at ingest with rejects quantified
Uniqueness	Duplicate rate	Deduplication with reporting

Two points that make the difference between a framework and a formality:

- **Measure against expectation, not against itself.** A feed that reports its own record count is not a control. The expected count must come from the source side or from an independent model.
- **Report the tail, not the mean.** Timeliness at the 50th percentile is irrelevant; what matters is how often a record is not available when an urgent request arrives. Assurance reporting that shows averages is concealing the failures.

11.4 Completeness statements

If Module 6 is right that absence of a record is weak evidence of absence of an event, then the disclosure must say what the system knows about its own completeness.

```
Disclosure for MSISDN X, period 01-02-2026 to 28-02-2026

Records returned: 47 sessions, 12 messages

Completeness:
  Session records    : complete, no known gaps
  Message records    : feed unavailable 14-02 08:00-16:00 (8h);
                       records for that window may be missing
  Location           : present for 41 of 47 sessions; 6 sessions
                       carried no access-network information
  Correlation        : 45 of 47 fully correlated; 2 partial
                       (interconnect component absent)

As at: 03-03-2026 09:14 UTC. Pipeline version 4.2.
```

That block is more useful to the recipient than a hundred extra records, and it is generatable automatically from the quality controls already described. It is also, if things ever go wrong,

the artefact that shows the operator disclosed the limitations of its own data rather than presenting it as complete.

The design requirement: the system must record feed outages, correlation failures and field-level absence *at the granularity of the query*, so that a completeness statement can be composed for any arbitrary period. Retrofitting this is very hard; designing it in is not.

11.5 Errors

The regime expects errors to be reported, which means the design must make them *detectable*. A taxonomy is the starting point:

Error class	Example	Detection
Wrong subject	Resolution returned the wrong subscriber, e.g. a reassigned number	Time-segmented resolution; post-hoc reconciliation
Excess disclosure	Data outside the authorised scope released	Requested/authorised/returned comparison in audit
Content disclosure	A content-bearing value reached the authority	Field classification checks on egress
Third-party over-disclosure	Unnecessary enrichment of the other party	Enrichment-off default; review
Incomplete disclosure	Silent feed loss	Volume reconciliation
Late disclosure	Missed statutory or agreed timescale	SLA instrumentation
Unauthorised query	Query run without valid authority	Query-to-authorisation reconciliation
Retention failure	Data kept beyond period, or destroyed early	Deletion evidence; sampling

For each class the design should define: how it is detected, how quickly, who is notified, how the affected disclosures are identified, and how the correction reaches the recipient. **That last step is routinely missing.** A system that can detect an error but cannot enumerate which past disclosures were affected cannot actually remediate, and "we have told them to disregard everything from that period" is a poor substitute.

11.6 The assurance evidence pack

What an inspection or an internal design authority should be able to receive, assembled largely automatically:

1. The data catalogue, with classifications, bases, periods and sign-offs.
2. The mapping from notice to schema, field by field, with gaps recorded.
3. Scope enforcement evidence: for a sample of disclosures, the requested, authorised and returned field sets and the computed intersection.
4. Quality reporting for the period across the six dimensions.
5. Deletion evidence for every expired partition.
6. Access review: who had which rights, when, and the accreditation status behind them.
7. Misuse detection output, including nil returns — evidence the controls ran.
8. Error register with remediation status.
9. Change record for the period, with capability-impact assessments and any notifications made.
10. Reconciliation with the acquiring authority's own records.

Governance note. Ask the programme to produce this pack for a single month, early — ideally before go-live, using test data. What cannot be produced is a gap in the design, and finding it at that point costs a fraction of finding it at the first inspection. It is the single most useful thing a design authority can demand.

Key takeaways

- Quality, integrity and evidential weight are three different standards; decide explicitly which disclosures need which.
- Evidential weight needs provenance, integrity, repeatability, explicability and continuity — and explicability is an architectural veto on opaque matching.
- Measure quality against independent expectation, and report the tail.
- Completeness statements that travel with the disclosure are cheap to generate and disproportionately valuable.
- Design the error taxonomy with the *remediation* path included: detecting an error you cannot trace to affected disclosures is not enough.
- Rehearse the assurance evidence pack before go-live.

Module 12 — Governing the Programme [G]

> **Objectives.** You can set up and run the design authority for a CDA programme; you can structure requirements that derive from a legal instrument; you can manage vendors and change in a regulated capability; and you can recognise the failure patterns early.

12.1 What is different about governing this

Five things, and each has a structural consequence.

The requirements baseline is a legal instrument. A notice is not a requirements document: it is written to be legally effective, not implementable. Somebody must translate it, and that translation is itself a governed artefact that must be re-validated when the notice changes.

The customer is not the user. The acquiring authority sets the demand; your own disclosure team uses the system; the Secretary of State compels the capability; the regulator inspects it; and none of them is the one funding it. Stakeholder management is not a soft skill here, it is the job.

Failure is asymmetric. Under-delivering is a compliance breach. Over- delivering — retaining more, returning more, building more capability than is required — is *also* a breach, and a more serious one in privacy terms. Programmes are instinctively built to over-deliver.

The evidence is part of the deliverable. A capability that works but cannot prove it worked is not done.

The lifetime is long and the sources churn. A retention capability outlives the network generation that fed it. Modularity is a compliance property.

12.2 The design authority

Membership. Enough to make the decision, small enough to make it. In practice: a chair with design authority; the solution architect; a security architect; someone who owns the legal interpretation; someone who owns the operational disclosure function; and data/privacy. The last two are the ones most often missing, and their absence shows up as designs that are elegant and unoperable, or compliant on paper and intrusive in practice.

What it decides, rather than notes. A useful design authority has a standing decision list. For this domain:

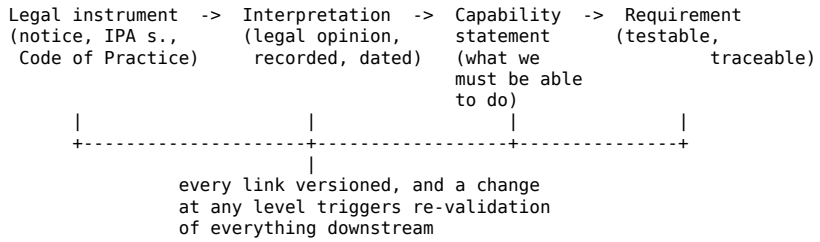
Decision	Why it is a DA decision
Field-level classification of anything arguable	It has legal effect (Module 3)
Where content truncation happens	Irreversible (Module 7)
Retention as copy vs system of record	Irreversible
Scope enforcement mechanism	Determines the assurance posture

Decision	Why it is a DA decision
Correlation key and treatment of uncorrelated records	Determines evidential explicability
Identifier expansion bound	Delegating it is delegating a legal judgement
Urgent path scope	Trades control against life safety
Human review rule	Where judgement sits
Nil-return vocabulary	Information the recipient cannot recover later
Source system-of-record nomination	Data quality accountability
Vendor production access model	Assurance case shape
Notifiable-change criteria	Regulatory obligation on your own lifecycle

> **Governance note.** If a programme's design authority is reviewing documents rather than taking decisions from a list like this, it is a reading group. The test is whether a decision taken there can be produced, with rationale and date, two years later.

12.3 Requirements that derive from law

A workable chain, and the reason each link exists:



Two disciplines make this work:

- **Never let a requirement cite the law directly.** "Shall comply with section 87" is untestable. It must cite an interpretation, which cites the law. When the law changes, you can find every affected requirement.
- **Record the negative decisions.** What you decided *not* to build, and why, is as important as what you built — it is the evidence of minimisation, and it is the first thing an inspector asks about when a capability looks narrower than the notice appears to require.

12.4 Vendors

Question	Why it matters	Bad answer
Which of the six layers does the product cover?	Boundaries determine where your controls go	"It's an end-to-end platform"
Where does scope enforcement happen in the product?	Module 7, Decision 3	"The user selects the authorisation"
Is the data model extensible without a vendor release?	Notices change	"We'll add it to the roadmap"
Can we export retained data and its schema, in bulk, ourselves?	Exit and portability are compliance issues	"We'd do a migration project"
What in the resolution or correlation path is heuristic or learned?	Explicability veto (Module 11)	"It's our proprietary matching"
How is production access by your staff controlled?	Module 10	"Standard support VPN"

Question	Why it matters	Bad answer
Can it produce the assurance pack in Module 11?	It is part of the deliverable	“We provide logs”
What is the upgrade path when the network generation changes?	Lifetime mismatch	“The product supports 5G today”

The general principle: **buy the plumbing, own the policy.** Storage, ingestion, indexing, delivery transport and workflow are commodity and should be bought. Classification, scope enforcement, correlation rules, the nil-return vocabulary, the caveat model and the audit schema are your compliance posture and should be specified by you, expressed in configuration you control, and portable between suppliers.

12.5 Change

Change is where compliant systems drift out of compliance, quietly.

Four change sources, four different controls:

Source	Example	Control
Legal	Amended Act, revised Code, new notice	Re-validate interpretation → capability → requirements chain
Network	IMS upgrade, new access technology, NAT redesign	Data supply agreements; source impact assessment
System	Release of your own platform	Capability-impact assessment; notifiable-change test
Demand	New request type from the authority	Scope and classification review before build

The capability-impact question belongs in your standard change record, as a mandatory field, phrased so it cannot be answered by reflex:

> *Does this change alter what communications data we generate, retain, can resolve, or can disclose — in kind, in granularity, in timeliness or in completeness? If yes, describe the change and the assessment reference.*

That single field, answered honestly on every change, is the operational mechanism behind both the notification-notice obligation and your own regression risk. It also produces, over time, a change history that is exactly what an inspection wants to see.

12.6 Failure patterns, and the early signal for each

Pattern	Early signal	Intervention
Requirements that the data cannot satisfy	Requirements about continuous location or OTT services	Publish the capability statement (Module 6) early
Scope creep into investigation	Features that “help the analyst” — link analysis, enrichment, saved subjects	Return to the CSP’s actual duty: disclose what is held
Compliance-by-documentation	A classification spreadsheet not referenced by any code	Make the catalogue a build artefact

Pattern	Early signal	Intervention
Billing coupling	Retention fed from charging with no gap analysis	Demand the gap analysis and change-coupling statement
Audit as logs	“We have comprehensive logging”	Ask for the assurance pack for one month
Urgent path as normal path	Rising urgent volumes	Report urgent volumes to the DA as standing item
Undeletable backups	No answer on backup expiry	Crypto-shredding design, or accept and document
Single-vendor lock	No export path	Portability clause and a rehearsed export
Silent feed loss	Nobody can say what yesterday’s expected volume was	Volume reconciliation (Module 8)
Accreditation drift	Access reviews are annual and manual	Accreditation as a checked attribute

12.7 A first hundred days

If you are picking this up cold, the sequence that recovers ground fastest:

1. **Get the instruments.** The notices, the current Code, the interpretation record. Read them before the architecture.
2. **Build the field-level catalogue**, even if it starts as an incomplete spreadsheet, and find out who has signed off the arguable classifications. Usually nobody has.
3. **Trace one real disclosure end to end** — request to response, with the audit — and see whether you can reconstruct it. This exposes more than a month of document review.
4. **Ask for last month’s expected-versus-actual volumes per feed.** If nobody can produce them, you have found the most serious operational gap.
5. **Run the assurance pack rehearsal** (Module 11) on test data.
6. **Establish the decision list** in §12.2 and find out which of those decisions have actually been taken, by whom, and when.
7. **Write the capability statement** and get it agreed with the acquiring authority.

Key takeaways

- The requirements baseline is a legal instrument and must be translated through a versioned interpretation chain; requirements never cite the law directly.
- Over-delivery is a breach too — record the negative decisions as evidence of minimisation.
- Buy the plumbing, own the policy: classification, scope, correlation, caveats and audit are your compliance posture and must be portable.
- A mandatory capability-impact question on every change is the operational mechanism behind both notification obligations and regression control.
- The fastest diagnostic in an unfamiliar programme is to trace one disclosure end to end and ask for last month’s expected-versus-actual feed volumes.

Appendix A — Design Review Question Bank

Grouped by review stage. Each question is written so that a weak design cannot answer it with an assertion.

A.1 Scope and legal basis

1. Which instrument generates this requirement — a retention notice, a technical capability notice, a national security notice, or a commercial agreement? Show me the clause.
2. Where is the interpretation record that sits between that clause and this requirement, and when was it last reviewed?
3. What have we decided *not* to build, and where is that recorded?
4. Which fields are classified as entity, which as events, and who signed off the arguable ones?
5. For each arguable classification, what is the rationale, and what would change it?
6. Are we building an ICR capability? If so, what precisely constitutes an ICR in our network, and who agreed that definition?

A.2 Data and sources

7. For each event type, which system is the system of record, and what happens when two sources disagree?
8. What is the data supply agreement for each source — completeness, timing, change notification — and who signed it?
9. Where is content-bearing granularity removed, and is that before or after storage?
10. Can a retained record be re-derived if a classification decision changes?
11. What is the correlation key, what proportion of records correlate fully, and what happens to the rest?
12. Is any part of the correlation or resolution path heuristic, probabilistic or learned? Who will explain it in a witness box?

A.3 Retention

13. Show me the mapping from notice to schema, field by field, with gaps.
14. How is expiry enforced, and what evidence does deletion produce?
15. Does backup retention exceed data retention? If so, what prevents restoring expired data?
16. How is legal hold implemented, authorised and time-bounded?
17. What is the assumed ratio of translation records to session records, and was it measured or assumed?
18. Does the capacity model include indexes, replicas and correlated copies?
19. What is the steady state at twelve months, not the growth curve?

A.4 Query, scope and disclosure

20. Where is scope enforced — procedurally, in the application, in a service, or in the data layer?
21. Is the authorisation machine-readable, and is it an input to the access decision on every request?
22. How many identifier hops can a resolution perform, is the bound configurable per authorisation, and is it audited?
23. Does resolution return time-segmented results with explicit gaps?
24. Can the system express ambiguity, or does it return a best guess?
25. What is the nil-return vocabulary, and does it distinguish “not our subscriber” from “no records”?
26. Is third-party enrichment on by default?
27. Where does a human review, and what is the rule that decides when review is required?

A.5 Interface

28. Show me the message catalogue. Is there a clarification message, a withdrawal, an amendment, an error and a nil return?
29. Are requests and responses individually signed?
30. Do both parties keep reconcilable audit, and does anyone actually reconcile them?
31. What is the urgent path, what request types does it support, and when was it last exercised out of hours?
32. How would we detect a run of well-formed but unauthorised requests from a compromised endpoint?

A.6 Security and access

33. Can platform engineers run disclosure queries? Prove it.
34. Who administers the audit compartment, and do they have an operational role?
35. Which actions require two people?
36. Is accreditation a checked system attribute or an HR record?
37. Do we detect self-queries and associate queries?
38. What is the vendor’s production access model, and is it standing or break-glass?
39. Who holds the keys, and does any single team hold enough to read the store?

A.7 Assurance

40. Produce the assurance evidence pack for one month.
41. What was last month’s expected versus actual record volume per feed, and where did the expectation come from?
42. Show me, for a sampled disclosure, the requested, authorised and returned field sets.
43. Can we generate a completeness statement for an arbitrary period?
44. For each error class, how is it detected, and can we enumerate the past disclosures it affected?
45. What is the capability-impact question on our change record, and show me three completed examples.

Appendix B — Patterns and Anti-Patterns

B.1 Patterns worth adopting

Catalogue as a build artefact. The field catalogue — classification, basis, period, source, owner — is machine-readable and consumed by the pipeline and the scope resolver. Schema and catalogue cannot drift because the catalogue generates the enforcement.

Interval-keyed bindings. Every association is (identifier, type, from, to). Every resolution takes a time and returns segments with explicit gaps. This one pattern prevents the largest class of wrongful disclosure.

Scope resolver as a service. A component beneath the application intersects the authorisation with the request and emits a permitted field set and period. Every query goes through it; the intersection is logged. Converts "we trained our staff" into "the system could not have."

Truncate at ingest, irreversibly. The content-bearing value never reaches storage. One engineering decision replaces a permanent operational risk.

Per-partition keys. Time partitions hold their own keys; expiry destroys the key. Deletion becomes provable and reaches backups.

Completeness statement as a first-class output. Feed outages, correlation failures and field absence are recorded at a granularity that lets a statement be composed for any query period, and it travels with the disclosure.

Two pipelines, one policy. Urgent and routine paths are physically distinct, with different latency targets and different review placement, but share the same scope resolver and the same audit.

Reconcilable audit at both ends. Both parties record every exchange in comparable form, and reconciliation runs automatically rather than on suspicion.

Negative decision register. What was deliberately not built, and why, kept as evidence of minimisation.

B.2 Anti-patterns, and what they cost

Anti-pattern	What it looks like	What it costs
The investigation workbench	Link analysis, saved subjects, enrichment, "related identities"	Drifts the CSP into investigation, exceeds the disclosure duty, and creates scope that no authorisation covers
Heuristic correlation	Time-and-identifier joining where no correlation key exists	Undetectable wrong disclosures; fails explicability

Anti-pattern	What it looks like	What it costs
Enrichment by default	Automatically resolving the other party's number to a name	Routine third-party over-disclosure, designed in
Scope in the UI	The application restricts what may be asked	Bypassable; weak evidence; fails at the data layer
Billing as the retention source, permanently	Charging feed retained as the compliance store	Coupling to a commercial roadmap; silent gaps
Single "search" service	Entity and events retrieval fused	The entity/events boundary becomes undemonstrable
Logs as audit	Operational logging repurposed	Not immutable, not complete, not retained long enough, not reconstructable
Best-guess resolution	Ambiguity collapsed to one answer	The recipient cannot detect the error
Deletion by job, not by evidence	A nightly purge with no artefact	Cannot demonstrate compliance; backups unaddressed
Standing vendor access	Support VPN into production	Indefensible under inspection; expands the trust boundary
Annual access review	Spreadsheet-driven, manual	Accreditation drift; stale privilege
The universal pipeline	One path for urgent and routine	Either too slow for threat-to-life or too loose for everything else

B.3 Two worked design decisions

Where to enforce scope

Context. Requests arrive with an authorisation reference. The authorisation permits certain data classes for a certain period.

Options. (a) Disclosure officers apply it. (b) The application restricts the form. (c) A scope-resolution service intersects authorisation and request and returns a permitted set that the query layer enforces. (d) Row and column security in the data layer bound to the authorisation.

Decision. (c), with (d) for the highest-sensitivity classes.

Rationale. (a) and (b) cannot produce the evidence an inspection needs and fail under volume. (d) alone is inflexible and slow to change as notices change. (c) puts the intersection in one auditable place, keeps the policy in configuration we own, and produces the requested/authorised/returned triple that the assurance pack depends on.

Consequences. Every request must carry machine-readable authorisation attributes — this becomes an interface requirement. The scope resolver is a high-assurance component with its own change control.

Retention source for voice session records

Context. Charging records already exist and are complete for billable events. The notice specifies session records including unanswered attempts.

Options. (a) Reuse charging. (b) Purpose-built collection from the S-CSCF and P-CSCF. (c) Charging now, purpose-built later.

Decision. (c), with a dated commitment and a published gap list.

Rationale. (a) cannot meet the notice — unanswered attempts are not billable — and couples compliance to the tariff roadmap. (b) is right but not deliverable in the required timescale. (c) delivers a partial capability honestly, provided the gaps are declared to the authority rather than concealed.

Consequences. A published gap list; a change-coupling statement naming who is consulted before billing changes; a capability statement update; and a date at which (c) becomes (b) or is re-decided.

Appendix C — IMS Protocol Reference Annex

The technical detail compressed out of the main text, for when you need to check a fact or challenge a vendor’s claim.

C.1 Nodes

Node	Full name	Function
P-CSCF	Proxy Call Session Control Function	First contact point for the device; access edge; asserts identity; requests QoS; sees access type, IP address, cell
I-CSCF	Interrogating CSCF	Network front door; asks the HSS which S-CSCF serves a user
S-CSCF	Serving CSCF	Always in the home network; registrar; authenticates; holds the user profile; triggers services; routes
HSS	Home Subscriber Server	Subscriber data, identity bindings, authentication
AS / TAS	Application Server / Telephony AS	Supplementary services: diversion, barring, waiting, transfer, conference
IBCF	Interconnection Border Control Function	Border to other operators; topology hiding; inserts inter-operator identifiers
MRFC / MRFP	Media Resource Function	Announcements, tones, conferencing
BGCF / MGCF	Breakout / Media Gateway Control	Routing and conversion to the circuit-switched world
IP-SM-GW	IP Short Message Gateway	SMS over IP
SCC AS	Service Centralization and Continuity AS	Access transfer, terminating access domain selection
E-CSCF / LRF	Emergency CSCF / Location Retrieval	Emergency routing and location

C.2 Identifiers

Identifier	Form	Notes
IMPI	`user@realm` (NAI)	Private; authentication only; on the ISIM

Identifier	Form	Notes
IMPU	`sip:user@domain` or `tel:+44...`	Public; several per subscriber; aliases share a service profile
IMSI	15 digits: MCC + MNC + MSIN	The SIM subscription
IMEI / IMEISV	15 / 16 digits	The device
MSISDN	E.164	The telephone number
GRUU	A URI with a `gr` parameter	Reaches one specific registered device
PSI	A URI naming a service	Conference factory, voicemail
ICID	`icid-value` in `P-Charging-Vector`	**The charging correlation identifier — preserved across nodes and across B2BUAs; the practical correlation key**
IOI	`orig-ioi` / `term-ioi`	Inter-operator identifiers; name the peer operator

C.3 Signalling elements that carry CD-relevant information

Element	Carries
`P-Asserted-Identity`	The identity the network vouches for — the reliable originator
`P-Called-Party-ID`	The identity that was dialled, preserved when the target is rewritten
`P-Access-Network-Info`	Access type (E-UTRAN, NR, WLAN) and cell identity — **the location source**
`P-Visited-Network-ID`	The visited network when roaming
`P-Charging-Vector`	ICID and inter-operator identifiers — **correlation**
`Contact` / `Path` / `Service-Route`	Registration binding and routing — establishes where a device was reachable
`From` / `To` / `Call-ID` / tags	Session and dialog identity — note that a B2BUA changes Call-ID, which is why ICID matters
Request-URI	The target; rewritten during routing, hence `P-Called-Party-ID`
SDP `m=` / `c=` lines	Media type, address and port — describes the event, not its meaning
Message body	**Content. Out of scope.**

C.4 Procedures that generate records

Procedure	Produces	CD value
Registration	Identity, contact address, access type, cell, time, expiry	Device attached here, then
Re-registration	Same, periodically	Presence over time, coarse
Deregistration	Time and reason	Device left
Session establishment	Both identities, time, service, media types	The core call record

Procedure	Produces	CD value
Service invocation	Which supplementary service applied, and any diversion target	Explains anomalous records
Session release	Time, duration, cause	Completes the record
Message send / deliver	Sender, recipient, time, delivery status	Messaging records
Access transfer	Old and new access, time	Explains a session that changed technology
Emergency session	Identity, location, PSAP	Handled under a separate regime

C.5 Interfaces you may see named

Reference point	Between	Protocol
Gm	Device ↔ P-CSCF	SIP
Mw	CSCF ↔ CSCF	SIP
ISC	S-CSCF ↔ Application Server	SIP
Cx / Dx	CSCF ↔ HSS / SLF	Diameter
Sh / Dh	AS ↔ HSS / SLF	Diameter
Ut	Device ↔ AS	XCAP over HTTP — subscriber's own service settings
Rx / N5	P-CSCF ↔ PCRF (4G) / PCF (5G)	Diameter / HTTP2 — QoS authorisation
Rf / Ro	Nodes ↔ charging	Diameter — offline / online charging
Ici / Izi	Operator ↔ operator	SIP / media
LI_X1 / X2 / X3	ADMF ↔ POI / MDF	3GPP LI internal: provisioning, IRI, content
LI_HI1 / HI2 / HI3	Operator ↔ authority	Tasking, IRI delivery, content delivery

C.6 The 4G and 5G context in one table

	4G (EPS)	5G (5GS)
Signalling bearer for IMS	EPS bearer on the "ims" APN, QCI 5	PDU session on the "ims" DNN, 5QI 5
Voice bearer	Dedicated bearer, QCI 1	QoS Flow, 5QI 1
Mobility control	MME	AMF
Session control	S-GW / P-GW	SMF / UPF
Policy	PCRF over Rx	PCF over N5
Subscriber data	HSS	UDM (commonly HSS+UDM combined)
Voice service	VoLTE (GSMA IR.92)	VoNR (GSMA NG.114), or EPS Fallback to 4G
CD implications	Location from E-UTRAN cell identity	Location from NR cell identity; EPS Fallback means a 5G call may produce 4G records

That last row is a real and frequently missed operational point: with EPS Fallback, a call initiated on 5G completes on 4G, so the session records may appear in the 4G-facing feeds

while the registration records are 5G-facing. A correlation design that assumes one access technology per session will fragment exactly these calls.

Appendix D — Legal and Standards Index

D.1 UK legislation and codes

Instrument	Relevance
Investigatory Powers Act 2016	The governing statute. Part 1 (s.11 offence), Part 3 (acquisition), Part 4 (retention), Part 8 (oversight), Part 9 (notices)
Investigatory Powers (Amendment) Act 2024	Amended the notices regime (including notification notices, s.258A), the bulk personal datasets regime (Parts 7A, 7B), the s.11 offence and the internet connection record conditions
Data Retention and Acquisition Regulations 2018	Introduced independent authorisation (OCDA) and the serious crime threshold for events data
Communications Data Code of Practice	The operational detail: how authorisations are made, what applications must contain, error reporting. Revised in 2025 following the 2024 Act
Notices Regime Code of Practice	New code covering retention, technical capability, national security and notification notices
Investigatory Powers (Codes of Practice, Review of Notices and Technical Advisory Board) Regulations 2025 (SI 2025/656)	Brought the revised and new codes into force; set notice review timelines; adjusted the Technical Advisory Board
Data Protection Act 2018 / UK GDPR	Applies to everything not compelled, and to the operator's handling throughout

Check the current consolidated text before relying on any of this: the amendments of 2024 and the 2025 regulations mean older secondary material and commentary may describe a superseded position.

D.2 ETSI

Standard	Subject
TS 103 120	Interface for warrant information — structured exchange of authorisations, tasks, notifications and delivery between authorities and operators. Actively maintained; versions through 2025

Standard	Subject
TS 102 657	Handover interface for the request and delivery of retained data; requesting and delivery interfaces and the retained-data schemas
TS 102 232 series	Handover specification for IP delivery — the delivery transport
TS 101 331	Requirements of law enforcement agencies
TS 102 656	Retained data requirements
TR 102 528 / TS 103 705 and related	Supporting architecture and profiling material

D.3 3GPP

Specification	Subject
TS 33.126	Lawful interception requirements
TS 33.127	LI architecture and functions — ADMF (LICF + LIPF), POIs, MDF2/MDF3, TF, LEMF; includes IMS in clause 7
TS 33.128	LI stage 3 — protocol and procedures, including IMS events
TS 33.108	Earlier handover specification; still found in legacy estates
TS 23.228	IMS architecture (stage 2)
TS 24.229	IMS SIP profile (stage 3)
TS 23.003	Numbering, addressing and identification — the identifier definitions
TS 32.260 / 32.299	IMS charging and the Diameter charging applications — where ICID is defined and carried

D.4 GSMA

Document	Subject
IR.92	IMS Profile for Voice and SMS (VoLTE)
IR.94	IMS Profile for Conversational Video
NG.114	IMS Profile for Voice, Video and Messaging over 5GS
IR.65	IMS Roaming and Interworking Guidelines

Appendix E — Glossary

ADMF — Administration Function; in 3GPP LI, the combination of the control function (LICF) and provisioning function (LIPF) that tasks the network.

CD — Communications data. **CDA** — communications data acquisition.

CGNAT — Carrier-grade NAT; address sharing that makes IP-to-subscriber resolution impossible without source port and accurate time.

Content — the meaning of a communication; requires an interception warrant; out of scope for CDA.

CSP / TO — Communications service provider / telecommunications operator.

DRN — Data retention notice, under Part 4 IPA 2016.

Entity data — data about an entity or about the association between an entity and a telecommunications service; the lower threshold category.

Events data — data identifying or describing an event on a telecommunication system; the higher threshold category.

HSS — Home Subscriber Server; the identity and subscription database.

ICID — IMS Charging Identifier; the correlation identifier preserved across IMS nodes, and the practical key for joining records about one session.

ICR — Internet connection record; a defined subset of events data subject to additional restrictions under section 62.

IMPI / IMPU — IMS private / public user identity.

IMS — IP Multimedia Subsystem; the operator's service core for voice, video and messaging.

IPA — Investigatory Powers Act 2016. **IP(A)A 2024** — the 2024 Amendment Act.

IPC / IPCO — Investigatory Powers Commissioner / Commissioner's Office; oversight and inspection.

IPT — Investigatory Powers Tribunal; redress.

LEMF — Law Enforcement Monitoring Facility; the authority's collection point.

MDF2 / MDF3 — Mediation and delivery functions for intercept-related information and for content respectively.

Notification notice — s.258A notice requiring an operator to notify the Secretary of State of relevant changes affecting capability; added by the 2024 Act.

NSN — National security notice, s.252.

OCDA — Office for Communications Data Authorisations; independent authorisation on behalf of most public authorities.

POI — Point of interception; the network function that generates intercept-related information or content.

P-CSCF / I-CSCF / S-CSCF — the three IMS call session control functions: access edge, network front door, and home serving node.

SPoC — Single Point of Contact; accredited staff within a public authority who quality-assure and submit requests.

TAS — Telephony Application Server; supplementary services.

TCN — Technical capability notice, s.253.

Third-party data — data about a person who is not the subject of the authorisation but appears in the records of the subject's communications.